420-1C2-DW · Threats and Risks · Class 3

Identifying Information Assets (Part 2)

Topic 2 — what Kalmia cannot lose, how its networks are built, who can access what · Lab 1 starts · Quiz 1

Saturday, October 24, 2026 · 2:00 – 6:00 pm · Online

AEC Cybersecurity: Prevention and Intervention (LEA.D8)

Competency EZ02 — performance criteria 1.3 and 1.4

Abbreviations: **AEC** (Attestation d'études collégiales, a Québec college-level professional program)

Asen Grozdanov
Cyber.SoHo Educational Hub

This hour and this afternoon

1 Data and services critical to the organization's operations

0:00 – 0:16

You can: run a business impact analysis: **MTD**, **RTO**, **RPO** and tier of every process, its dependencies, gaps and single points of failure.

2 Physical and logical representation of the infrastructure (network diagrams)

0:16 – 0:32

You can: draw and check the physical view (racks, ports, jacks) and the logical view (subnets, zones, trust boundaries, flows).

3 Documenting who has access to what (permissions map)

0:32 – 0:47

You can: compute effective access from **ACL** entries, compare it with the role matrix and classify the access findings.

4 Lab 1 — Asset inventory and infrastructure map — start

0:47 – 0:57

You can: prepare the Lab 1 folder and workbook, plan the work until November 5 and use the readiness check.

Q Quiz 1 — briefing — know when, where and how Quiz 1 is taken and what it covers

0:57 – 1:00

This afternoon

3:10 – 4:30
Lab 1 — guided work session

4:40 – 5:15
Quiz 1 on **TIC-FP**

5:15 – 6:00
Lab 1 — continued, questions and wrap-up

Abbreviations: **ACL** (access control list) · **MTD** (maximum tolerable downtime) · **RPO** (recovery point objective) · **RTO** (recovery time objective) · **TIC-FP** (the Chamilo-based online learning platform of the course)

Legal and ethical notice — read before any lab

- Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved.
- Use only in an isolated, authorized lab environment, against the targets an exercise designates.
- Unauthorized access may be a criminal offence — Criminal Code, ss. 342.1, 342.2, 430(1.1) and 184.
- Today's scripts read only the fictional Kalmia files; real modes only on authorized lab systems (6.1, 6.7).
- Diagrams, permissions maps and Lab 1 are confidential findings (7.5).
- Kalmia is fictional — never search for or test a real company (7.9); lab data only (18).
- Quiz 1 and its questions are confidential (17.2).
- Check every link before clicking — VirusTotal, Google Safe Browsing (14.2, Annex C).
- Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0 (link in the module).

§

Today, what you produce is confidential

6.1	Authorization before any real mode
6.7	Data and privacy in labs: fictional accounts only
7.5	**BIA**, diagrams, permissions map: confidential findings
7.9	Kalmia is fictional: never test a real company
17.2	Quiz 1 and its questions are confidential
18	Lab 1: lab data only, and your own work

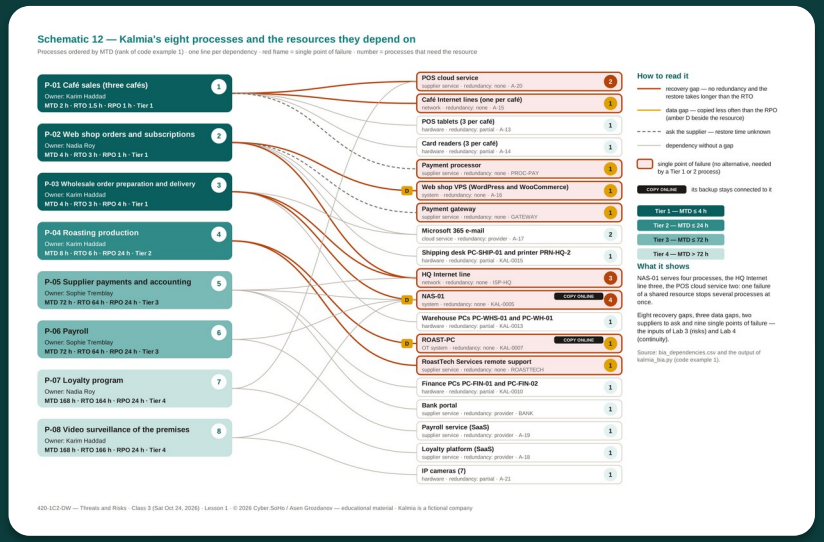
Abbreviations: **BIA** (business impact analysis)

1

Lesson 1 · 0:00 – 0:16

Data and services critical to the organization's operations

- From the inventory to what the business cannot lose
- Business process, critical data, critical service
- The business impact analysis — three steps
- **MTD**, **RTO**, **WRT** and **RPO**
- Dependencies, single points of failure, backups



Schematic 12 — Kalmia's eight processes and the resources they depend on

Abbreviations: **MTD** (maximum tolerable downtime) · **RPO** (recovery point objective) · **RTO** (recovery time objective) · **WRT** (work recovery time)

From the inventory to what the business cannot lose

- Class 2: what Kalmia owns · today: what it cannot lose, and for how long
- The answer comes from the people who run the business, not from the network
- EZ02 · criterion 1.3: complete identification of the critical data and services
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 · GV.OC-05 (Govern function, Organizational Context): services the organization depends on
- **NIST CSF** 2.0 · GV.OC-04: services customers expect · ID.AM-04 (Identify function, Asset Management): supplier services
- **NIST CSF** 2.0 · ID.AM-07: data inventories · **CIS** (Center for Internet Security) Safeguard 3.2: data inventory, reviewed yearly

1.3

EZ02 — critical data and services

GV.OC-05

NIST CSF 2.0 — services the organization depends on

ID.AM-07

NIST CSF 2.0 — data inventories

3.2

CIS Safeguard — data inventory, reviewed yearly

Business process, critical data, critical service

- **Business process** — activities that produce a result: sell, prepare, pay
- **Critical data** — needed by a critical process, or harmful if disclosed or altered
  - recorded in its three states: at rest · in transit · in use
- **Critical service** — an **IT** (information technology) or supplier service that a critical process needs
- Many critical services are outside the premises: no network scan finds them
- They are collected by interviewing the owners and reading the contracts

Where critical data and services are

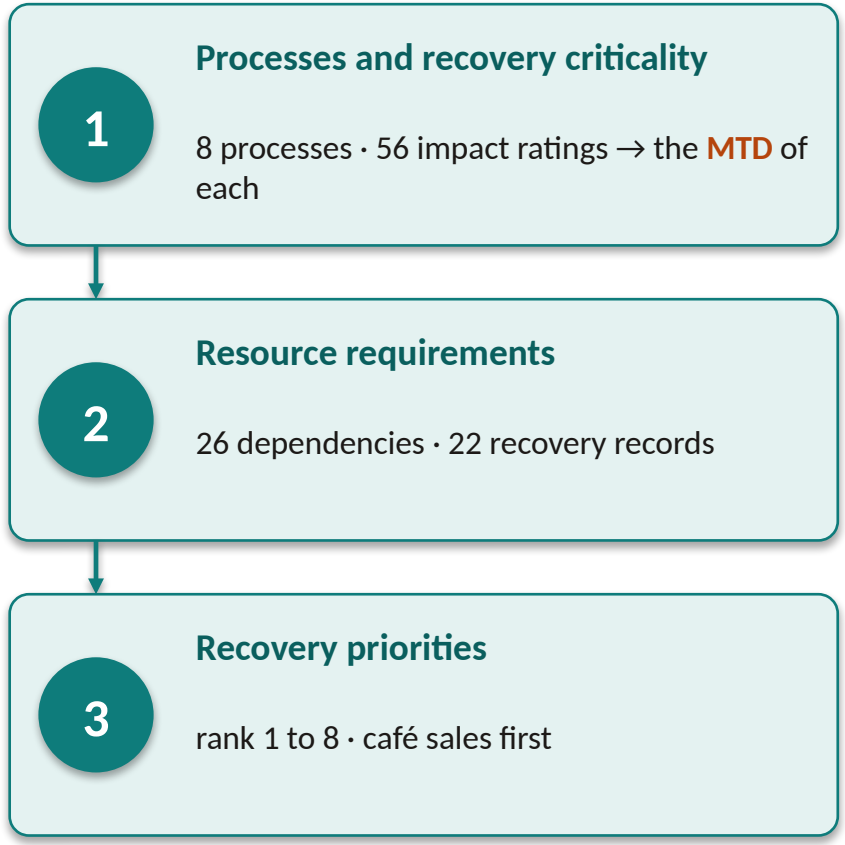
At rest	stored: NAS-01 shares, **POS** cloud records
In transit	moving: a card payment to the processor
In use	open: the daily order plan on screen
Outside	**POS** cloud · processor · web shop host

Abbreviations: **POS** (point of sale)

The business impact analysis — three steps

- **NIST** (National Institute of Standards and Technology) glossary: a **BIA** (business impact analysis) analyses the business processes and the effect a disruption would have on them
- **NIST SP** (Special Publication) 800-34 Rev. 1, the contingency planning guide, defines three steps:
  - 1 · determine the processes and their recovery criticality
  - 2 · identify the resource requirements
  - 3 · identify the recovery priorities
- **ISO** (International Organization for Standardization) 22301 makes the same analysis a core activity of business continuity
- Step 1: the owner rates the impact of an outage at 1, 2, 4, 8, 24, 72 hours and one week

The three steps, applied to Kalmia



Abbreviations: **MTD** (maximum tolerable downtime)

Step 1 — the impact of an outage of café sales

Outage	Financial	Reputation	Legal	Operations	Owner's note
1 hour	1	2	1	2	Queues; some card customers leave
2 hours	**2**	**3**	**1**	**2**	**About $1,000 lost (INC-03: 2 h 15 min)**
4 hours	2	3	1	3	
8 hours	2	3	1	3	
24 hours	2	4	1	3	About $7,500 of café sales per day
72 hours	3	4	1	4	
1 week	4	5	1	4	About $52,000 per week

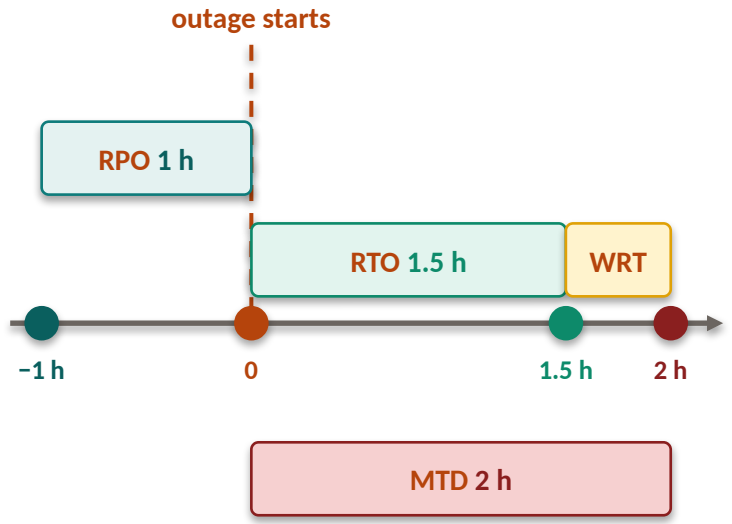
Kalmia's rule: the MTD is the first duration at which any category reaches 3 (serious)
Café sales reach 3 for reputation at 2 hours → **MTD** 2 h

Abbreviations: **MTD** (maximum tolerable downtime)

MTD, RTO, WRT and RPO

- **MTD** (maximum tolerable downtime) — total time a process can be down before the harm is unacceptable to its owner
- **RTO** (recovery time objective) — time allowed to restore the systems and data; shorter than the **MTD**
- **WRT** (work recovery time) — verify the data, enter what was written on paper, restart: **MTD** = **RTO** + **WRT**
- **RPO** (recovery point objective) — maximum age of the last good copy; it concerns data loss, not the **MTD**
- Café sales: **MTD** 2 h · **WRT** 0.5 h · **RTO** 1.5 h · **RPO** 1 h → Tier 1
- Tiers of Class 2: ≤ 4 h Tier 1 · ≤ 24 h Tier 2 · ≤ 72 h Tier 3 · longer Tier 4

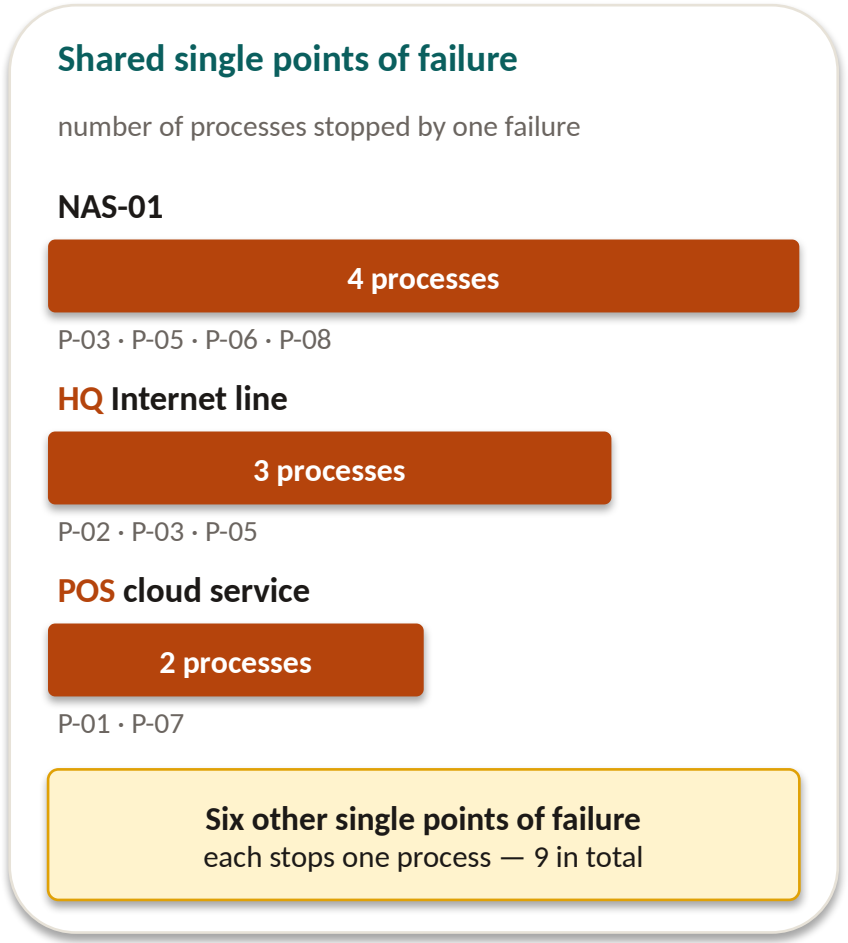
Café sales (P-01) on a time line



RPO — at most 1 h of sales data may be lost
RTO — systems back within 1.5 h
WRT — 0.5 h to check the data and enter the paper sales
MTD 2 h = **RTO** 1.5 h + **WRT** 0.5 h → Tier 1

Dependencies, gaps and single points of failure

- **Dependency** — any resource a process needs, inside or outside the company
  - recorded with its type, its redundancy and its workaround
- **Recovery gap** — no redundancy, and the restore takes longer than the **RTO** (recovery time objective)
- **Data gap** — copied less often than the **RPO** (recovery point objective) requires
- **Single point of failure** — no alternative; its failure alone stops a process
- Shared at Kalmia: NAS-01 → 4 processes · **HQ** (headquarters) Internet line → 3 · **POS** (point of sale) cloud → 2



A shared single point of failure — Rogers, July 8, 2022

- During a planned upgrade, a routing filter was removed from the distribution routers
- One router sent more than 900,000 routes into the core routers (normally about 10,000)
- Wireless and wireline services share one core network: both stopped
- More than 12 million customers; 9-1-1 calls failed; about 26 hours — **CRTC** (Canadian Radio-television and Telecommunications Commission) report, 2024
- Interac Debit and Interac e-Transfer were unavailable across Canada
- Interac then added a secondary network carrier and a third link (June 2023)

900,000+

routes sent into the core (normally about 10,000)

12 million+

customers without service

~26 h

length of the outage

2023

Interac: a secondary carrier and a third link

Backups that survive the incident

- A backup is useful only if it survives the incident it is meant for
- BKP-USB-01 stays plugged into NAS-01: ransomware reaches both in the same minute
- For every backup: frequency, restore time, one offline or off-site copy, a tested restore
- A restore time nobody has measured is an estimate, not a capability
- **NIST** (National Institute of Standards and Technology) **IR** (Interagency or Internal Report) 8286D: the **BIA** (business impact analysis) also covers the loss of confidentiality and integrity
- Employee files are not needed by the hour, but their disclosure would harm → Lesson 3

Four questions for every backup

How often?	at least as often as the **RPO**
How fast?	restore time measured, within the **RTO**
Offline?	one copy that ransomware cannot reach
Tested?	a real restore, with its date

BKP-USB-01 is always plugged into NAS-01
it fails the question “Offline?”

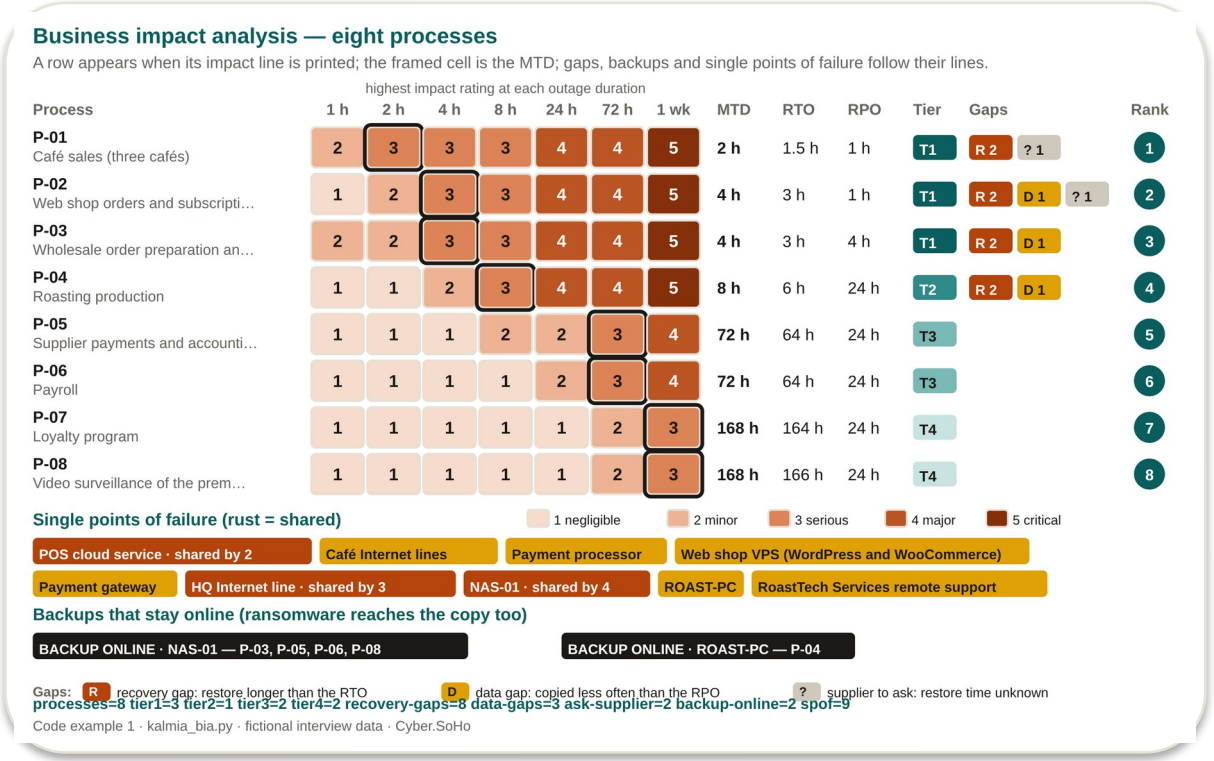
Abbreviations: **RPO** (recovery point objective) · **RTO** (recovery time objective)

Real-life example 1 — the first business impact analysis

Result	What the analysis found
Tier 1 — 3	**MTD** (maximum tolerable downtime): café sales (P-01) 2 h · web shop (P-02) 4 h · wholesale preparation (P-03) 4 h
Tiers 2, 3, 4	roasting (P-04) 8 h · payments (P-05) and payroll (P-06) 72 h · loyalty (P-07) and cameras (P-08) one week
Recovery gaps — 8	**POS** (point of sale) cloud 2.25 h > **RTO** (recovery time objective) 1.5 h · café and **HQ** (headquarters) Internet lines 24 h (3 gaps) · web shop **VPS** (virtual private server) 6 h · NAS-01 12 h · ROAST-PC 48 h · RoastTech 24 h
Data gaps — 3	web shop **VPS** and NAS-01 Production copied every 24 h · roast profiles copied once a week
Ask the supplier — 2	payment processor · payment gateway: restore time not in the contract
Backups online — 2	NAS-01 (BKP-USB-01 always plugged in) · ROAST-PC (profiles copied to NAS-01)
Single points of failure — 9	shared: NAS-01 (4) · **HQ** Internet line (3) · **POS** cloud service (2)

Code example 1 — kalmia_bia.py (Python)

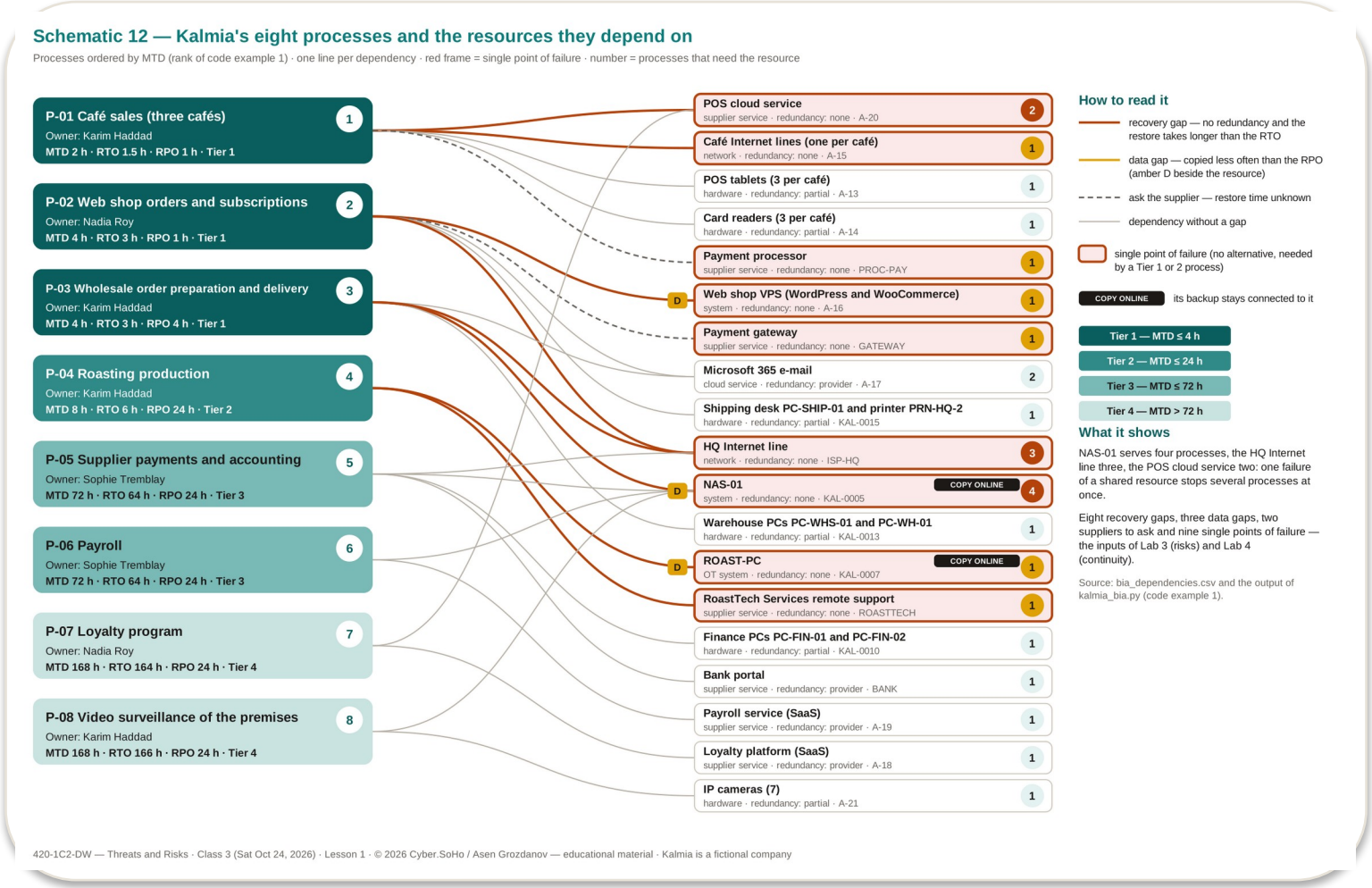
- Reads 8 processes, 56 ratings, 26 dependencies, 22 recovery records
- **MTD** (maximum tolerable downtime) = first duration rated 3 or more · **RTO** (recovery time objective) = **MTD** − **WRT** (work recovery time) · tier
- Tests every dependency: RECOVERY-GAP, DATA-GAP, ASK-SUPPLIER
- Finds backups that stay online and single points of failure
- Ranks the processes and writes two **CSV** (comma-separated values) files → Lab 1, Part D
- In the module: Start, Pause, Step, Next output, Restart — and the execution window



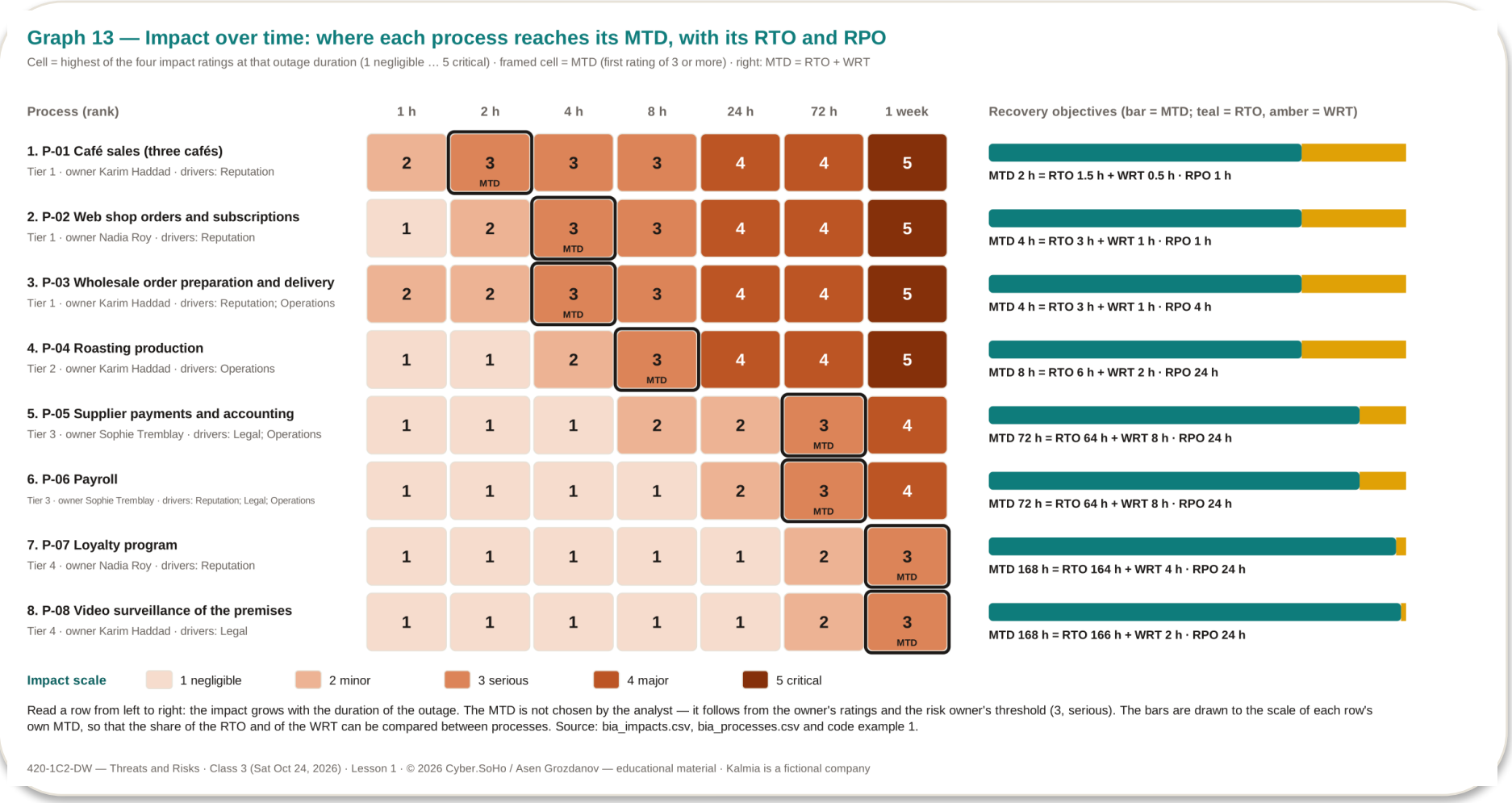
Final state of the code runner's visualization in the lecture module

```
$ python kalmia_bia.py bia_processes.csv bia_impacts.csv bia_dependencies.csv recovery_capability.csv
```

Schematic 12 — Kalmia's eight processes and the resources they depend on



Graph 13 — Impact over time, MTD, RTO and RPO



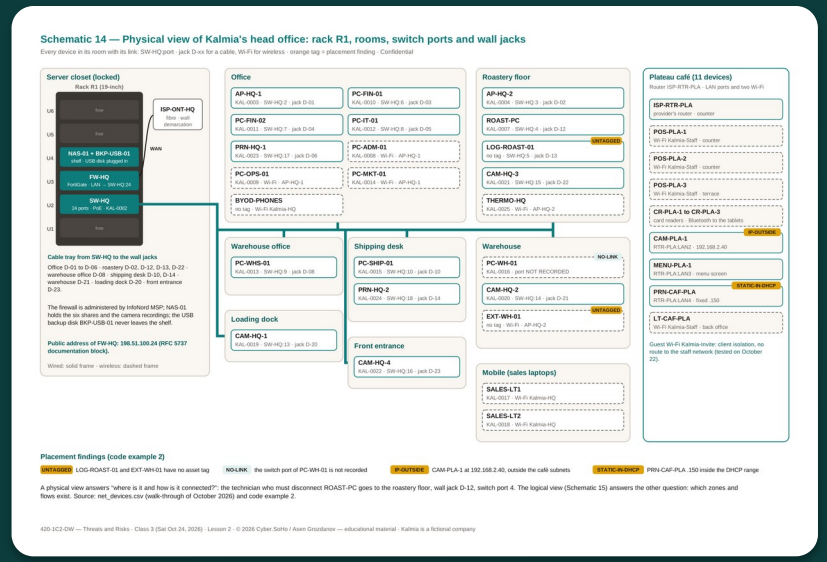
Abbreviations: **MTD** (maximum tolerable downtime) · **RPO** (recovery point objective) · **RTO** (recovery time objective)

2

Lesson 2 · 0:16 – 0:32

Physical and logical representation of the infrastructure (network diagrams)

- Why a list is not enough
- The physical view — rooms, racks, ports, jacks
- The logical view — subnets, zones, flows, trust boundaries
- Kalmia's flat network — and the Target breach
- Rules that make a diagram trustworthy



Schematic 14 — Physical view of Kalmia's head office: rack R1, rooms, switch ports and wall jacks

Why a list is not enough

- Inventories say what exists — not how it is connected or where data leaves
- EZ02 · criterion 1.4: correct representation of the physical and logical elements
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 · ID.AM-03 (Identify function, Asset Management): representations of network communication and data flows
- **CIS** (Center for Internet Security) Safeguard 12.4: architecture diagrams, reviewed yearly or after a significant change
- Two questions, two diagrams:
  - where is each device, and how is it connected? → physical view
  - how does information flow between groups of devices? → logical view

1.4

EZ02 — physical and logical elements

ID.AM-03

NIST CSF 2.0 — communication and data flows

12.4

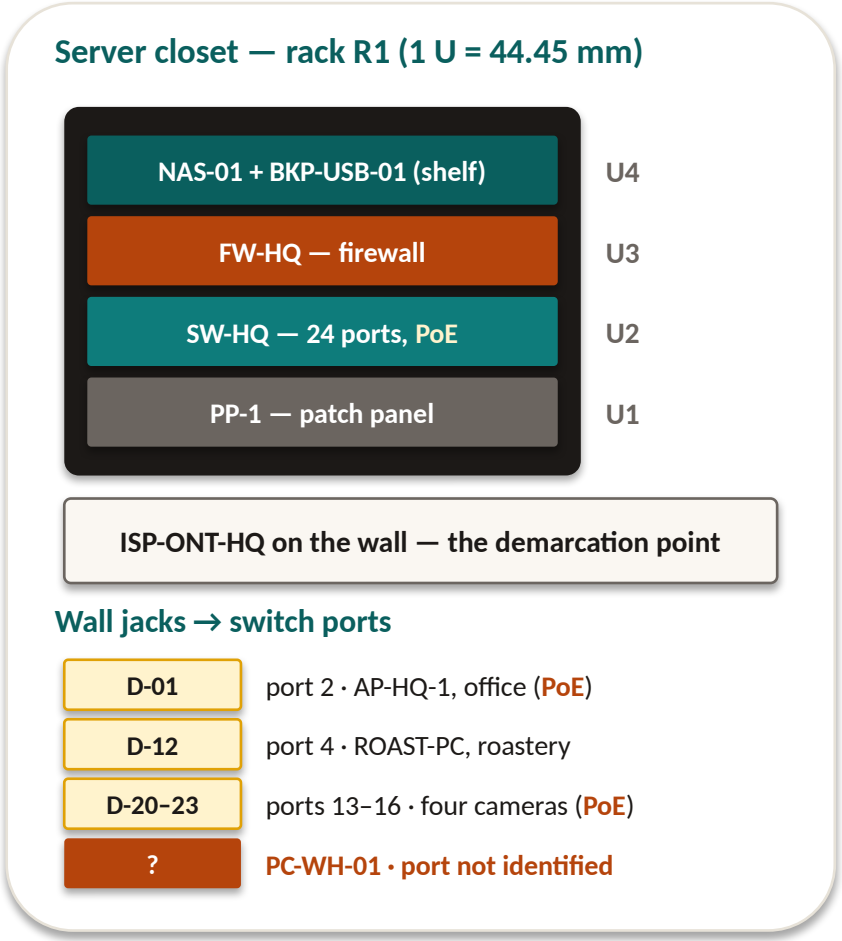
CIS Safeguard — architecture diagrams

2

views: physical and logical

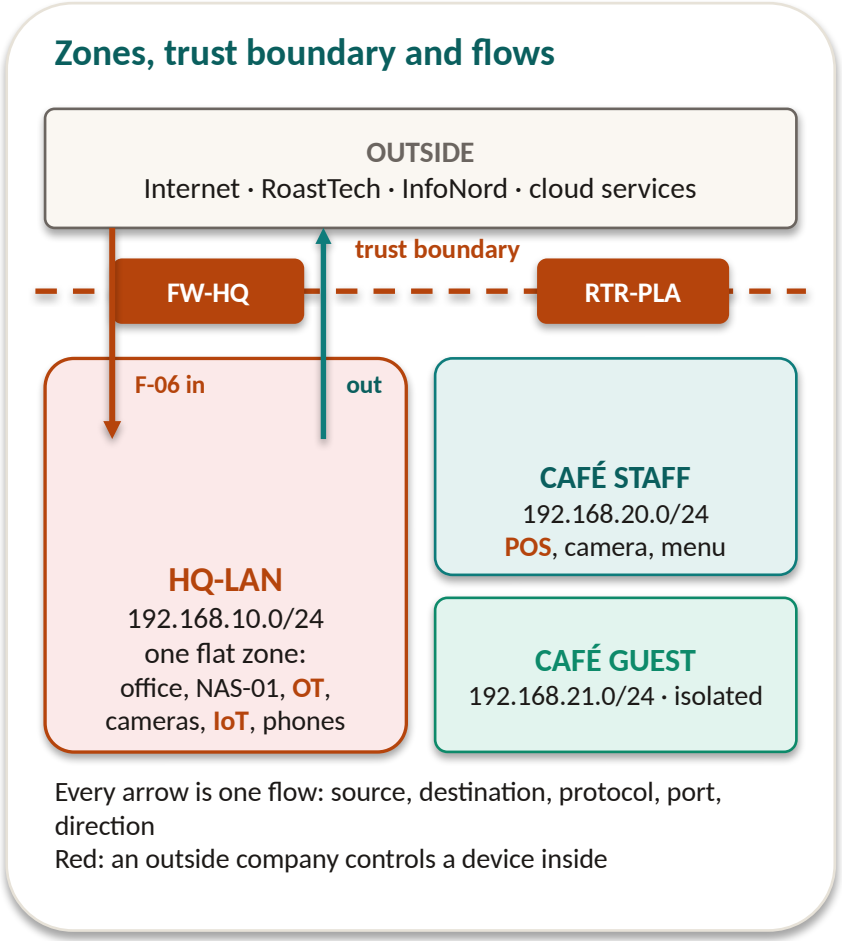
The physical diagram — where things are and how they are connected

- Equipment as installed: sites, rooms, racks — position in **rack units (U)** of 44.45 mm
- Cables with the switch port and the wall jack at each end; Wi-Fi access points
- The provider's demarcation point — **OSI** (Open Systems Interconnection, the seven-layer reference model of networking) Layer 1, the physical layer
- Used to isolate a device in an incident, to plan changes, to check physical security
- Kalmia: rack R1 — FW-HQ at U3, SW-HQ at U2, NAS-01 and its **USB** (Universal Serial Bus) disk at U4
- Jacks: D-01 office access point · D-12 ROAST-PC · D-20 to D-23 cameras powered by **PoE** (Power over Ethernet)



The logical diagram — subnets, zones, flows and trust boundaries

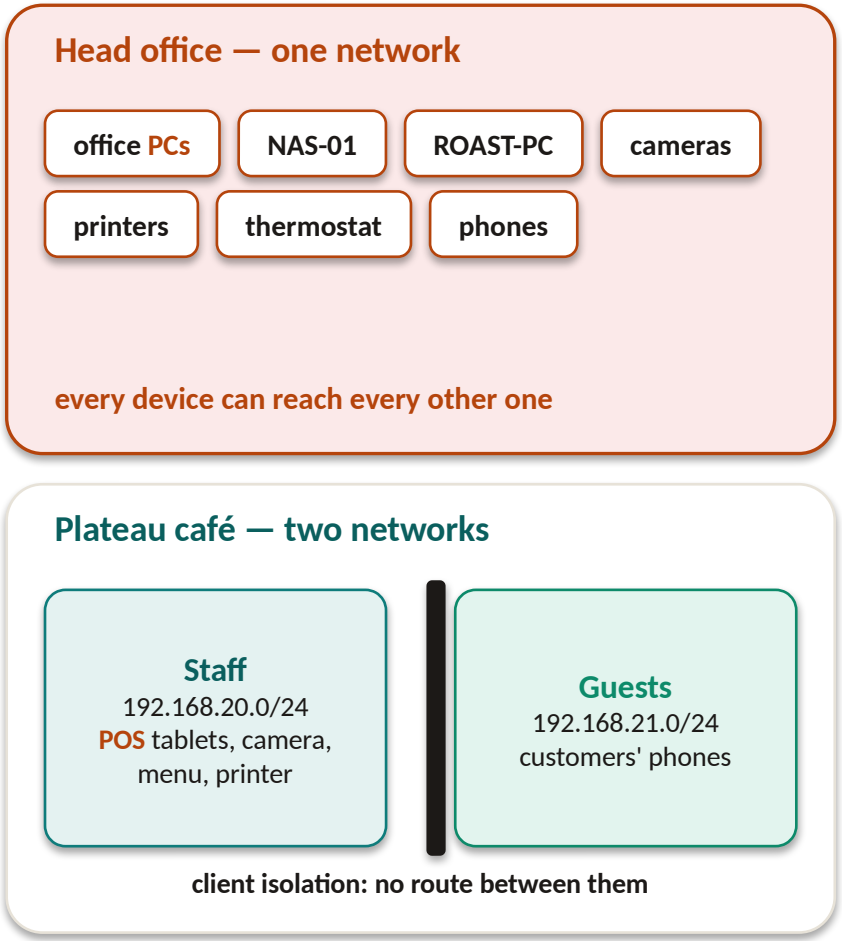
- How information moves — **OSI** (Open Systems Interconnection, the seven-layer reference model of networking) Layer 3: subnets, routers, firewalls
- **Zones** — devices with the same protection needs and the same rules
- **Data flows** — source, destination, protocol, port, direction
- **Trust boundary** — between zones of different trust levels
- Every crossing passes a control: firewall rule, authentication, encryption, approval with an end date
- Segmentation: Cyber Centre ITSM.10.092 · **CIS** (Center for Internet Security) Safeguards 12.2 and 3.12



Abbreviations: **IoT** (Internet of Things) · **OT** (operational technology) · **POS** (point of sale)

Kalmia's head office: one flat network

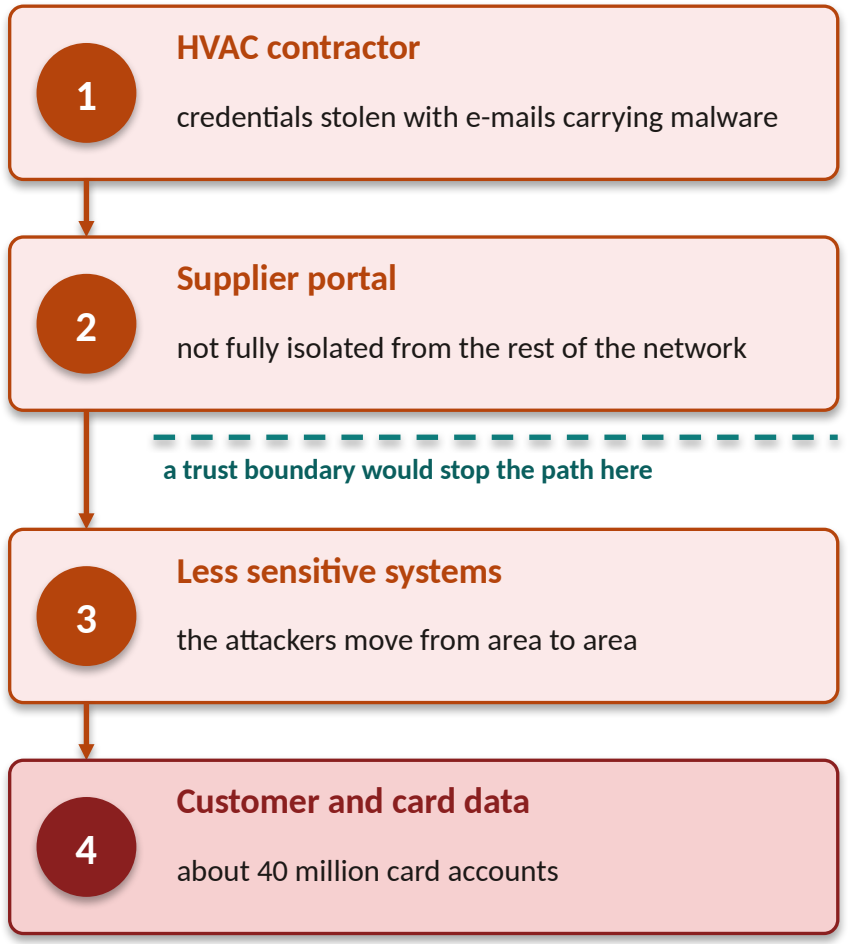
- One subnet, 192.168.10.0/24, and no rule between the devices
- Office computers, NAS-01, ROAST-PC, the logger, cameras, printers, thermostat, phones
- **Flat network** — one zone in which every device can reach every other one
- One compromised camera or phone can reach the file server and the roaster
- The cafés are better designed: guest Wi-Fi 192.168.21.0/24 isolated from staff 192.168.20.0/24



Abbreviations: **PC** (personal computer) · **POS** (point of sale)

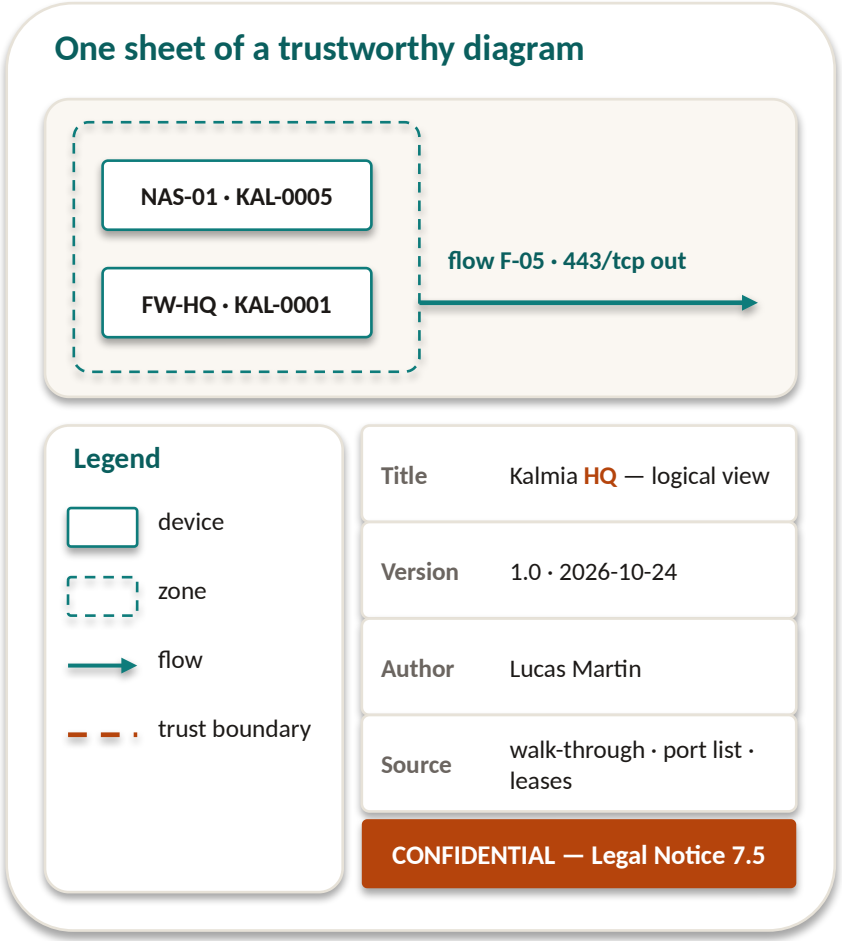
An uncontrolled path — the Target breach of 2013

- Credentials of an **HVAC** (heating, ventilation and air conditioning) contractor stolen through e-mails infected with malware
- Used to enter a supplier portal that was not fully isolated from the rest of the network
- The attackers moved from less sensitive areas to the systems holding customer data
- About 40 million card accounts; personal information of up to 70 million customers
- U.S. Senate committee report, March 26, 2014: Target failed to isolate its most sensitive assets
- A trust boundary around the payment systems would have shown the supplier's path



Rules that make a diagram trustworthy

- One diagram, one view — the physical and logical views are two files
- The same names everywhere — hostname and asset tag of the inventory
- A title block and a legend — version, date, author, data source, Confidential
- Documentation addresses — **RFC** (Request for Comments, the numbered documents that define Internet standards) 5737: 192.0.2.0/24 · 198.51.100.0/24 · 203.0.113.0/24
- Verify, then date — port list, **DHCP** (Dynamic Host Configuration Protocol) leases, physical check
- diagrams.net (draw.io): Arrange > Insert > Mermaid turns the script's text into shapes



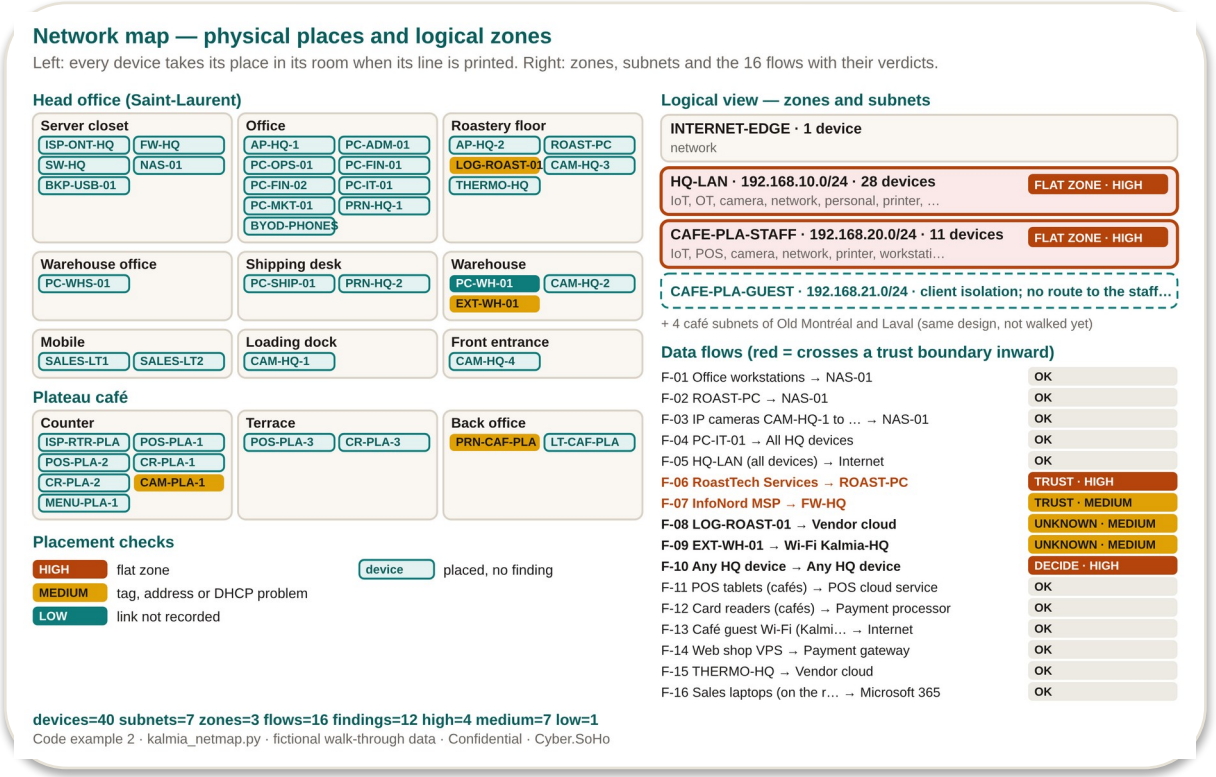
Abbreviations: **HQ** (headquarters)

Real-life example 2 — drawing the head office and the Plateau café

Check	What the walk-through found
Zoning — HIGH 2	HQ-LAN mixes **OT** (operational technology), cameras, **IoT** (Internet of Things) and phones with NAS-01 and the office · café staff zone mixes a camera and a screen with the **POS** (point of sale)
Trust boundary — HIGH 1, MEDIUM 1	F-06 RoastTech controls ROAST-PC with no end date · F-07 InfoNord administers FW-HQ (contract to June 30, 2027)
Flows — HIGH 1, MEDIUM 2	F-10 any device to any device, never decided · F-08 logger to vendor cloud and F-09 Wi-Fi extender: unknown
Placement — MEDIUM 4, LOW 1	two untagged devices · CAM-PLA-1 at 192.168.2.40 · fixed .150 inside the **DHCP** (Dynamic Host Configuration Protocol) range · PC-WH-01 port not recorded
Drawn	physical view: head office (29 devices) and Plateau café (11) · logical view: 3 zones, guest subnet, 16 flows

Code example 2 — kalmia_netmap.py (Python)

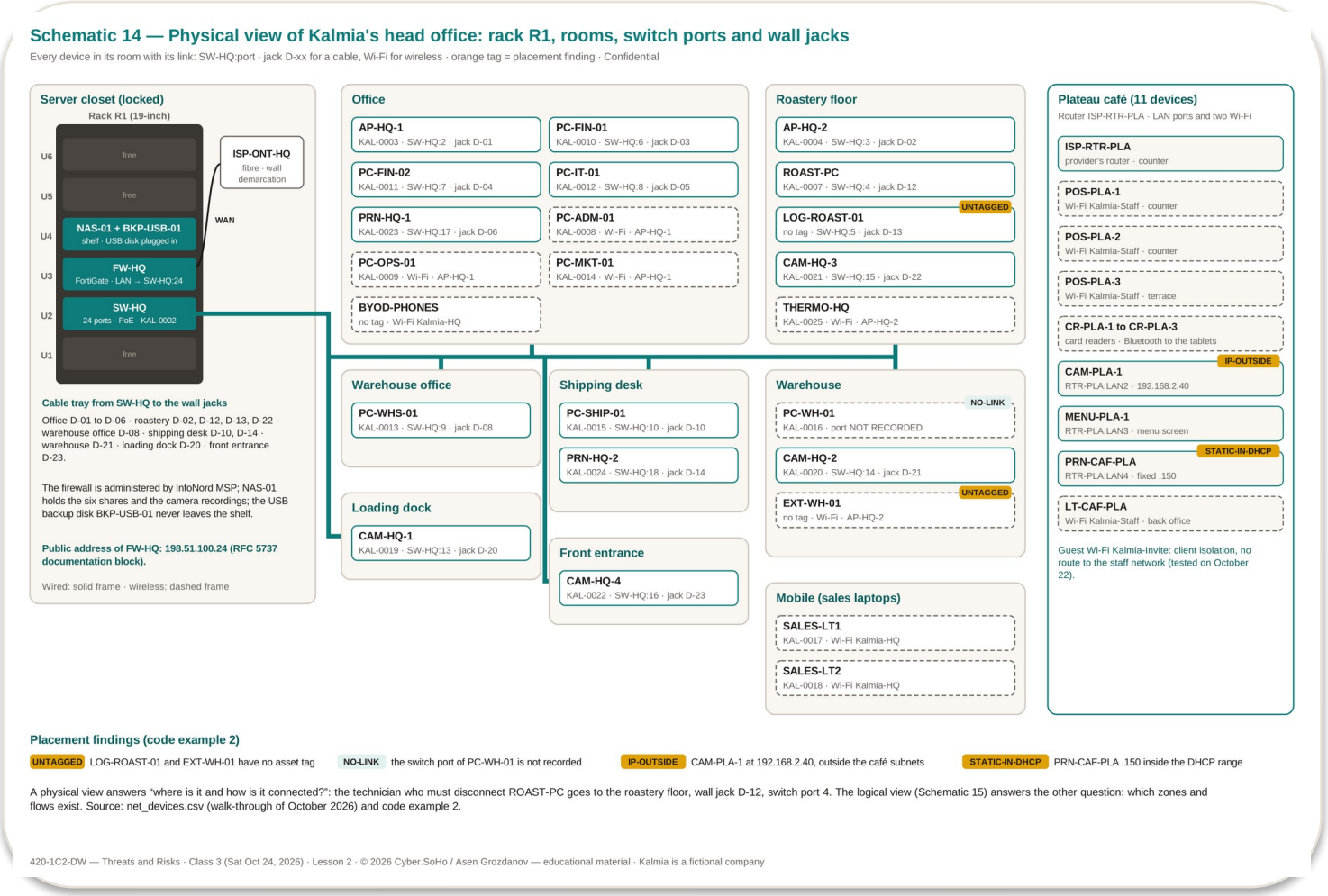
- Reads 40 devices, 7 subnets, 16 flows
- Checks links, tags and addresses with Python's ipaddress module
- FLAT-ZONE: families to separate mixed with families to protect
- Rates flows: TRUST-BOUNDARY, UNKNOWN, DECISION-NEEDED
- Writes physical_view.mmd and logical_view.mmd for draw.io
- Writes network_map_check.csv → Lab 1, Part E



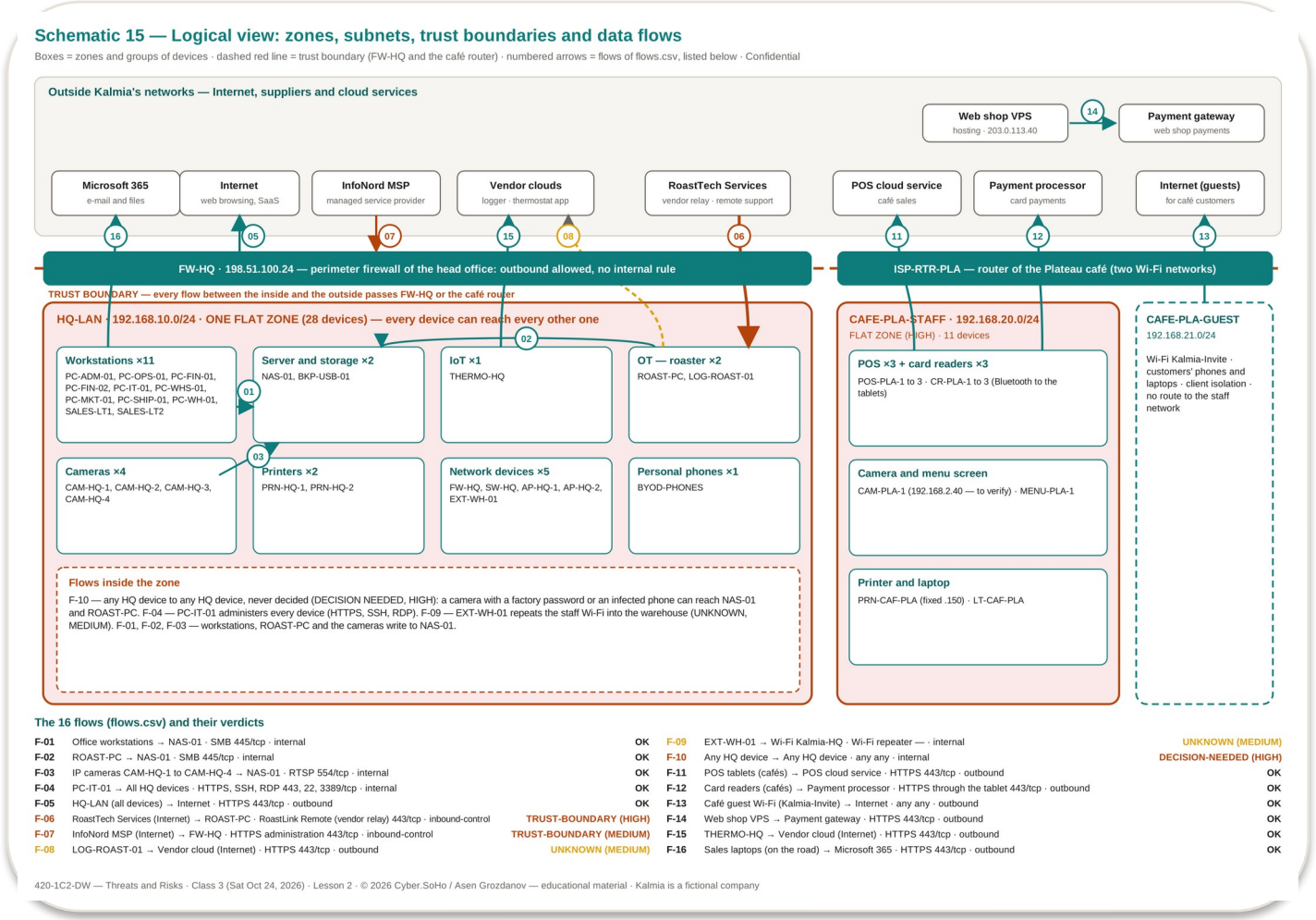
Final state of the code runner's visualization in the lecture module

```
$ python kalmia_netmap.py net_devices.csv subnets.csv flows.csv
```

Schematic 14 — Physical view of Kalmia's head office



Schematic 15 — Logical view: zones, trust boundaries and flows

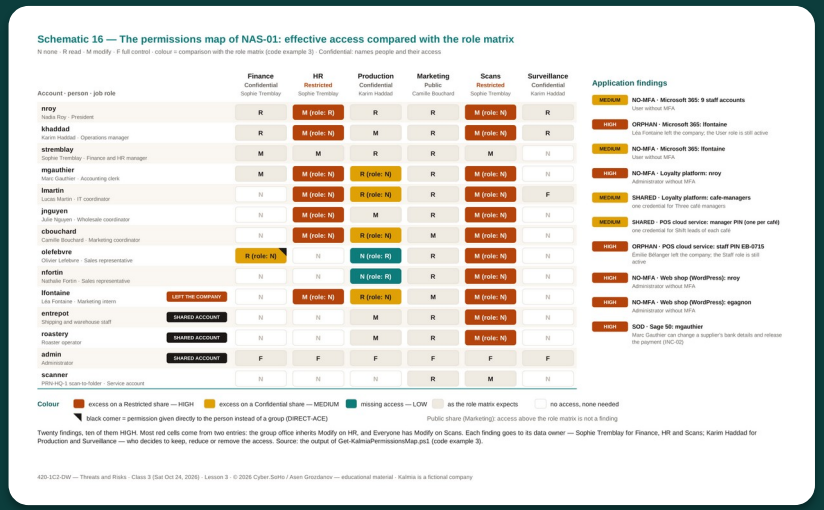


3

Lesson 3 · 0:32 – 0:47

Documenting who has access to what (permissions map)

- Identities, accounts, groups
- **ACLs**, **ACEs** and effective access
- The role matrix and need to know
- Seven kinds of findings
- The access life cycle and the access review



Schematic 16 — The permissions map of NAS-01: effective access compared with the role matrix

N none · R read · M modify · F full control · colour = comparison with the role matrix (code example 3) · Confidential: names people and their access

Account · person · job role		Finance Confidential Sophie Tremblay	HR Restricted Sophie Tremblay	Production Confidential Karim Haddad	Marketing Public Camille Bouchard	Scans Restricted Sophie Tremblay	Surveillance Confidential Karim Haddad
nroy Nadia Roy · President		R	M (role: R)	R	R	M (role: N)	R
khaddad Karim Haddad · Operations manager		R	M (role: N)	M	R	M (role: N)	R
stremblay Sophie Tremblay · Finance and HR manager		M	M	R	R	M	N
mgauthier Marc Gauthier · Accounting clerk		M	M (role: N)	R (role: N)	R	M (role: N)	N
lmartin Lucas Martin · IT coordinator		N	M (role: N)	R (role: N)	R	M (role: N)	F
jnguyen Julie Nguyen · Wholesale coordinator		N	M (role: N)	M	R	M (role: N)	N
cbouchard Camille Bouchard · Marketing coordinator		N	M (role: N)	R (role: N)	M	M (role: N)	N
olefebvre Olivier Lefebvre · Sales representative		R (role: N)	N	N (role: R)	R	M (role: N)	N
nfortin Nathalie Fortin · Sales representative		N	N	N (role: R)	R	M (role: N)	N
lfontaine Léa Fontaine · Marketing intern	LEFT THE COMPANY	N	M (role: N)	R (role: N)	M	M (role: N)	N
entrepot Shipping and warehouse staff	SHARED ACCOUNT	N	N	M	R	M (role: N)	N
roastery Roaster operator	SHARED ACCOUNT	N	N	M	R	M (role: N)	N
admin Administrator	SHARED ACCOUNT	F	F	F	F	F	F
scanner PRN-HQ-1 scan-to-folder · Service account		N	N	N	R	M	N

Application findings

- MEDIUM — NO-MFA · Microsoft 365: 9 staff accounts — User without MFA
- HIGH — ORPHAN · Microsoft 365: lfontaine — Léa Fontaine left the company; the User role is still active
- MEDIUM — NO-MFA · Microsoft 365: lfontaine — User without MFA
- HIGH — NO-MFA · Loyalty platform: nroy — Administrator without MFA
- MEDIUM — SHARED · Loyalty platform: cafe-managers — one credential for Three café managers
- MEDIUM — SHARED · POS cloud service: manager PIN (one per café) — one credential for Shift loads of each café
- HIGH — ORPHAN · POS cloud service: staff PIN EB-0715 — Émilie Bélanger left the company; the Staff role is still active
- HIGH — NO-MFA · Web shop (WordPress): nroy — Administrator without MFA
- HIGH — NO-MFA · Web shop (WordPress): epagnon — Administrator without MFA
- HIGH — SOD · Sage 50: mgauthier — Marc Gauthier can change a supplier's bank details and release the payment (INC-02)

Colour — excess on a Restricted share — HIGH · excess on a Confidential share — MEDIUM · missing access — LOW · as the role matrix expects · no access, none needed

black corner = permission given directly to the person instead of a group (DIRECT-ACE) · Public share (Marketing): access above the role matrix is not a finding

Twenty findings, ten of them HIGH. Most red cells come from two entries; the group office inherits Modify on HR, and Everyone has Modify on Scans. Each finding goes to its data owner — Sophie Tremblay for Finance, HR and Scans; Karim Haddad for Production and Surveillance — who decides to keep, reduce or remove the access. Source: the output of Get-KalmiaPermissionsMap.ps1 (code example 3).

420-1C2-DW — Threats and Risks · Class 3 (Sat Oct 24, 2026) · Lesson 3 · © 2026 Cyber.SoHo / Asen Grozdarov — educational material · Kalmia is a fictional company

Schematic 16 — The permissions map of NAS-01: effective access compared with the role matrix

Abbreviations: **ACE** (access control entry) · **ACL** (access control list)

From administrator rights to access to information

- Class 2: who can administer each device · today: who can read, change or delete each set of information
- **Permissions map** — identities in rows, resources in columns, effective access in every cell
- Course learning outcome: identify and represent all information assets and their permissions
- **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0 · PR.AA-05 (Protect function, Identity Management, Authentication and Access Control): permissions defined, managed, enforced and reviewed
  - with least privilege and separation of duties

84

cells: 14 accounts × 6 shares

PR.AA-05

NIST CSF 2.0 — permissions managed and reviewed

20

findings in Kalmia's first map

10

of them HIGH

Identity, account, group, ACL, ACE

- **Identity** — the person or program · **account** — its representation in one system
- Named, shared and service accounts (scanner is the printer's account)
- **Group** — one permission given once to all its members
- **ACL** (access control list) — the list attached to a folder; each **ACE** (access control entry) names a trustee, a permission, allow or deny, inherited or not
- Windows tools: Get-Acl (PowerShell) · icacls (command line) · Get-SmbShareAccess (share permissions)

\\NAS-01\HR — Restricted
data owner: Sophie Tremblay

Its ACL — three ACEs (all Allow)

Trustee	Permission	Inherited
NAS-01\hr	Modify	no
NAS-01\office	**Modify**	**yes**
NAS-01\administrators	FullControl	yes

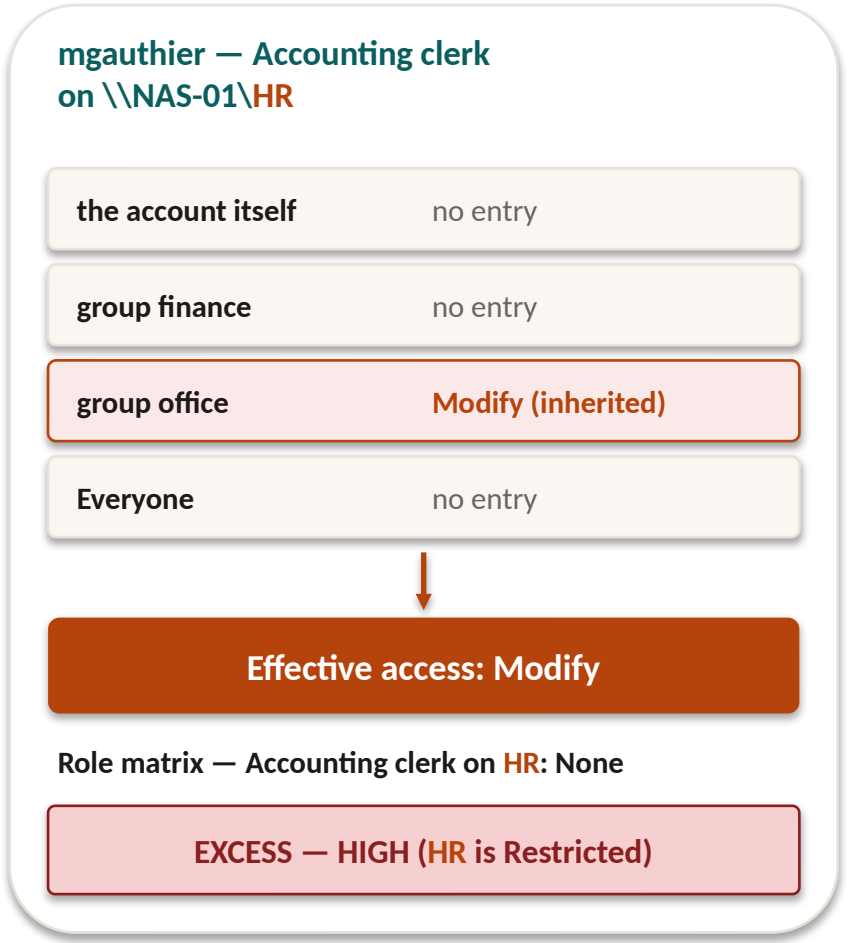
office = 7 people
the inherited entry gives all of them Modify on the employee files

Read with Get-Acl (PowerShell) or icacls; share permissions with Get-SmbShareAccess

Abbreviations: **HR** (human resources)

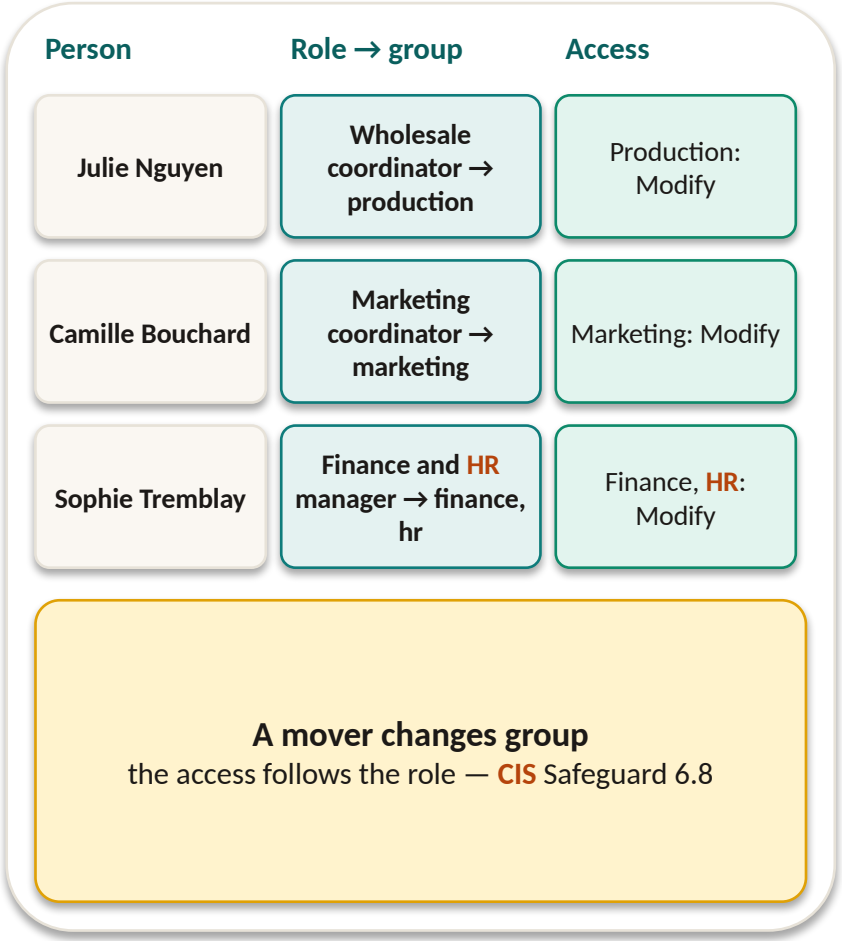
Effective access

- **Effective access** — every entry for the account, its groups and Everyone, combined
- Allowed permissions add up; an explicit Deny wins
- Over the network: the more restrictive of the share and the **NTFS** (New Technology File System, the Windows file system) permissions
- Kalmia's export holds Allow entries only → the highest level granted
- mgauthier: office has Modify on **HR** (inherited) → Modify, while his role needs none
- Everyone has Modify on Scans → every account opens the scanned **HR** forms; 11 beyond the role matrix



The role matrix and need to know

- **Role matrix** — the access each job role needs, agreed with the data owners
- **Need to know** — access only when the job requires it; **CIS** (Center for Internet Security) Safeguard 3.3
- Québec, P-39.1 s. 20: employees access personal information only if needed for their duties
- **RBAC** (role-based access control) — permissions are given to roles, which are groups; people receive roles
- A person who changes jobs changes group: the access follows the role
- **CIS** Safeguard 6.8: role-based access control, reviewed at least yearly



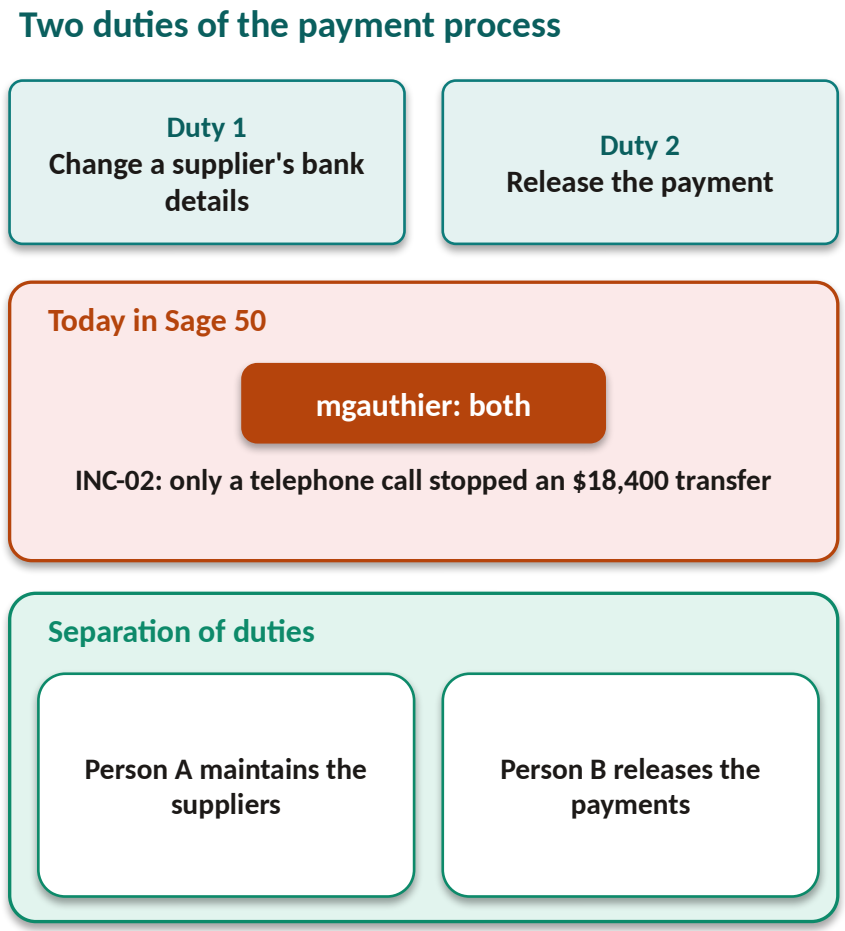
Abbreviations: **HR** (human resources)

Seven kinds of findings

Finding	Definition	Kalmia example
EXCESS	More access than the role matrix allows (with the entry that grants it)	office has Modify on **HR** (human resources), inherited: 7 people
MISSING	Less access than the job requires — availability	sales representatives cannot read Production
ORPHAN	Account still active after its owner left	lfontaine · staff **PIN** (personal identification number) EB-0715
SHARED	One account for several people: no accountability	admin: three employees and the **MSP** (managed service provider)
DIRECT-ACE	Permission given to one person, not a group	olefebvre: ReadAndExecute on Finance
NO-MFA	Privileged or exposed account without **MFA** (multi-factor authentication)	web shop administrators nroy, egagnon
SOD (separation of duties)	One person holds two duties that must be separated	mgauthier: bank details + payment (INC-02)

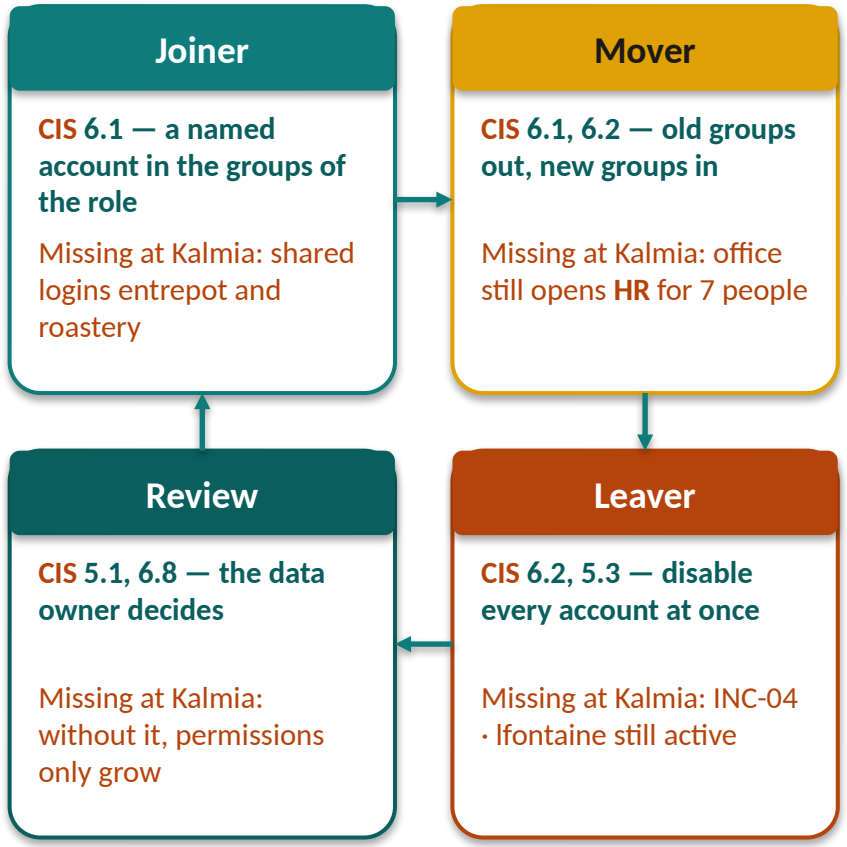
Separation of duties — the scenario of INC-02

- **Separation of duties** — critical functions divided among different people
- **NIST** (National Institute of Standards and Technology) glossary: no single person can commit a fraud alone and hide it
- Sage 50: mgauthier can change a supplier's bank details and release the payment
- INC-02: only Karim Haddad's telephone call stopped an $18,400 transfer
- Fix: one person maintains the suppliers, another releases the payments



The access life cycle and the access review

- **Joiner, mover, leaver** — three moments when access must change
- **CIS** (Center for Internet Security) 6.1: grant on hiring or role change · 6.2: revoke immediately on termination
- **CIS** 5.1: inventory of accounts validated quarterly · 5.3: dormant accounts disabled after 45 days
- Cyber Centre ITSM.10.094: separate administrator accounts, regular review
- **Access review** — the owner keeps, reduces or removes each access; the custodian applies
- INC-04: no leaver step — 18,500 loyalty records exported two months after a departure



The data owner decides; the custodian applies

Abbreviations: **HR** (human resources)

Too much access — the Desjardins case (OPC, 2020)

- Office of the Privacy Commissioner of Canada — news release, December 14, 2020
- An employee exfiltrated the personal information of nearly 9.7 million Canadians
- Over at least 26 months
- Data copied from data warehouses to a shared drive reachable without need
- Access controls and data governance found insufficient
- A permissions map compared with a role matrix detects such a share first

9.7 million

Canadians whose personal information was exfiltrated

26 months

at least, by one employee

2020

OPC news release, December 14

Shared drive

reachable without a need to know

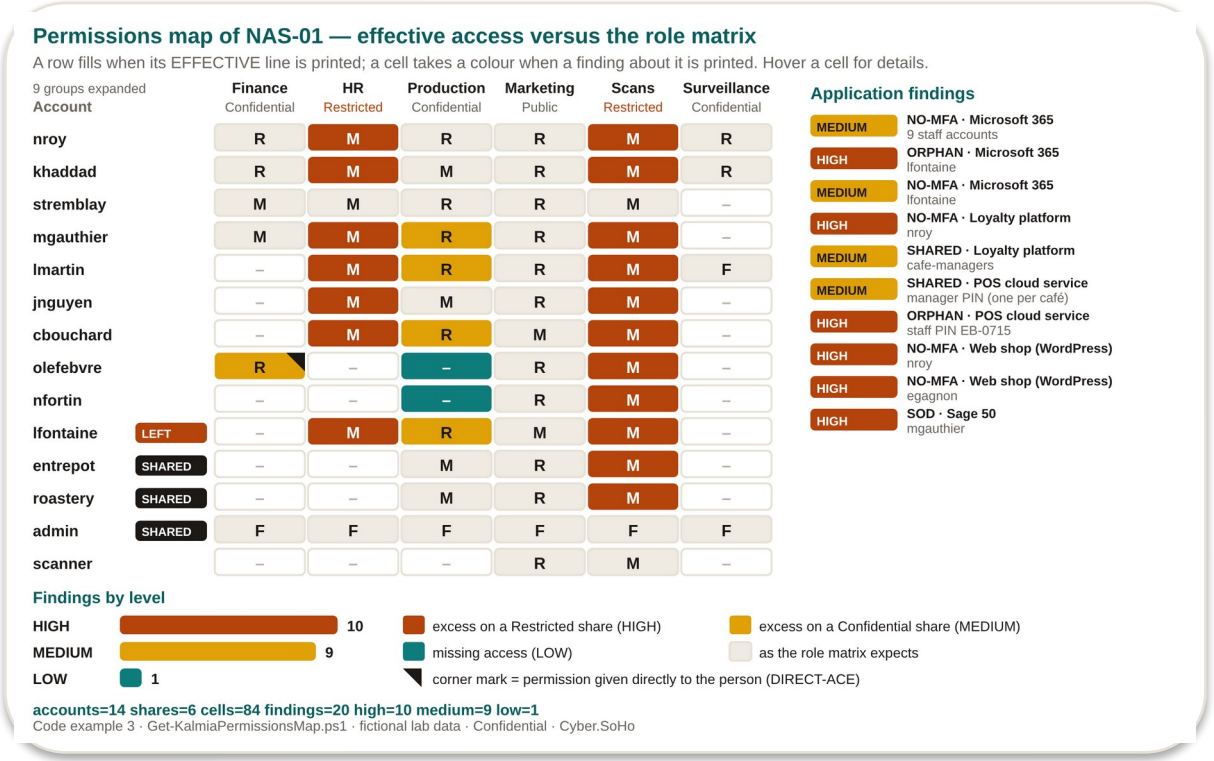
Abbreviations: **OPC** (Office of the Privacy Commissioner of Canada)

Real-life example 3 — the first permissions map of NAS-01

Finding	Level	Examples and the owner's decision to obtain
EXCESS	HIGH 2 · MEDIUM 2	**HR** (human resources) via the inherited office entry · Scans via Everyone → remove both, grant by role (Sophie Tremblay, Karim Haddad)
ORPHAN	HIGH 3	lfontaine on NAS-01 and Microsoft 365 · staff **PIN** (personal identification number) EB-0715 → disable today, leaver checklist
SHARED	HIGH 1 · MEDIUM 4	admin: three employees and the **MSP** (managed service provider) · entrepot · roastery · cafe-managers · manager **PINs**
NO-MFA	HIGH 3 · MEDIUM 2	loyalty and web shop administrators · 9 Microsoft 365 staff accounts · lfontaine
SOD (separation of duties)	HIGH 1	Sage 50: mgauthier → two people for two duties
DIRECT-ACE · MISSING	MEDIUM 1 · LOW 1	olefebvre on Finance · sales cannot read Production → group permissions

Code example 3 — Get-KalmiaPermissionsMap.ps1 (PowerShell)

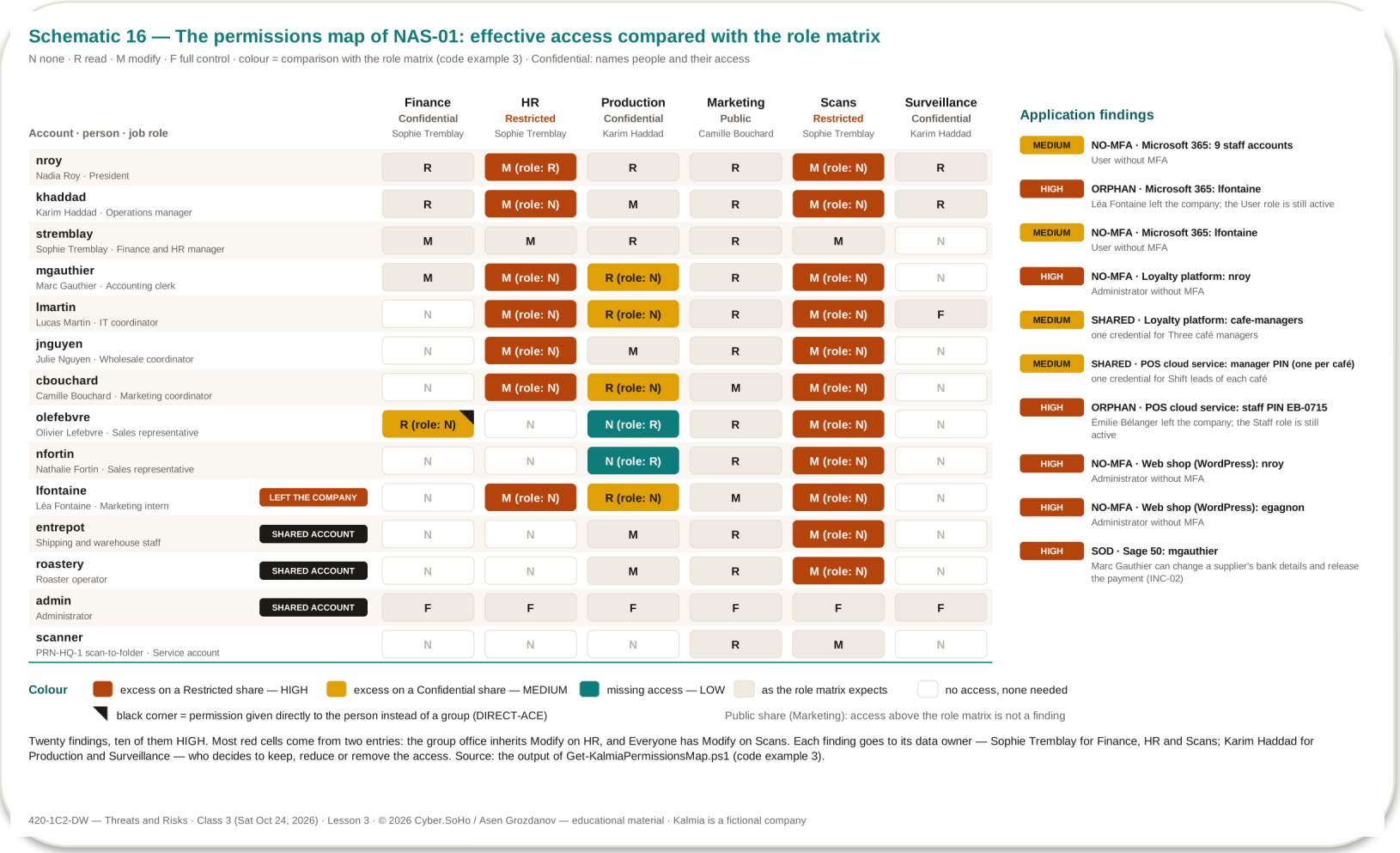
- Reads 18 **ACL** (access control list) entries, 6 shares, 15 accounts, the role matrix, 17 app roles
- Expands the groups into accounts
- Effective access: the highest level granted — 84 cells
- EXCESS grouped by the entry that grants it; MISSING
- ORPHAN · SHARED · DIRECT-ACE · NO-MFA · **SOD** (separation of duties)
- Writes permissions_map.csv and access_findings.csv → Lab 1, Part F



Final state of the code runner's visualization in the lecture module

```
PS> .\Get-KalmiaPermissionsMap.ps1 -InputFolder .\perms
```

Schematic 16 — The permissions map of NAS-01



Schematic 16 — The permissions map of NAS-01: effective access compared with the role matrix

N none · R read · M modify · F full control · colour = comparison with the role matrix (code example 3) · Confidential: names people and their access

Account · person · job role		Finance Confidential Sophie Tremblay	HR Restricted Sophie Tremblay	Production Confidential Karim Haddad	Marketing Public Camille Bouchard	Scans Restricted Sophie Tremblay	Surveillance Confidential Karim Haddad
nroy Nadia Roy · President		R	M (role: R)	R	R	M (role: N)	R
khaddad Karim Haddad · Operations manager		R	M (role: N)	M	R	M (role: N)	R
stremblay Sophie Tremblay · Finance and HR manager		M	M	R	R	M	N
mgauthier Marc Gauthier · Accounting clerk		M	M (role: N)	R (role: N)	R	M (role: N)	N
lmartin Lucas Martin · IT coordinator		N	M (role: N)	R (role: N)	R	M (role: N)	F
jnguyen Julie Nguyen · Wholesale coordinator		N	M (role: N)	M	R	M (role: N)	N
cbouchard Camille Bouchard · Marketing coordinator		N	M (role: N)	R (role: N)	M	M (role: N)	N
olefebvre Olivier Lefebvre · Sales representative		R (role: N)	N	N (role: R)	R	M (role: N)	N
nfortin Nathalie Fortin · Sales representative		N	N	N (role: R)	R	M (role: N)	N
lfontaine Léa Fontaine · Marketing intern	LEFT THE COMPANY	N	M (role: N)	R (role: N)	M	M (role: N)	N
entrepot Shipping and warehouse staff	SHARED ACCOUNT	N	N	M	R	M (role: N)	N
roastery Roaster operator	SHARED ACCOUNT	N	N	M	R	M (role: N)	N
admin Administrator	SHARED ACCOUNT	F	F	F	F	F	F
scanner PRN-HQ-1 scan-to-folder · Service account		N	N	N	R	M	N

Application findings

- MEDIUM — **NO-MFA · Microsoft 365: 9 staff accounts**
  User without MFA
- HIGH — **ORPHAN · Microsoft 365: lfontaine**
  Léa Fontaine left the company; the User role is still active
- MEDIUM — **NO-MFA · Microsoft 365: lfontaine**
  User without MFA
- HIGH — **NO-MFA · Loyalty platform: nroy**
  Administrator without MFA
- MEDIUM — **SHARED · Loyalty platform: cafe-managers**
  one credential for Three café managers
- MEDIUM — **SHARED · POS cloud service: manager PIN (one per café)**
  one credential for Shift leads of each café
- HIGH — **ORPHAN · POS cloud service: staff PIN EB-0715**
  Émilie Bélanger left the company; the Staff role is still active
- HIGH — **NO-MFA · Web shop (WordPress): nroy**
  Administrator without MFA
- HIGH — **NO-MFA · Web shop (WordPress): egagnon**
  Administrator without MFA
- HIGH — **SOD · Sage 50: mgauthier**
  Marc Gauthier can change a supplier's bank details and release the payment (INC-02)

Colour — excess on a Restricted share — HIGH · excess on a Confidential share — MEDIUM · missing access — LOW · as the role matrix expects · no access, none needed

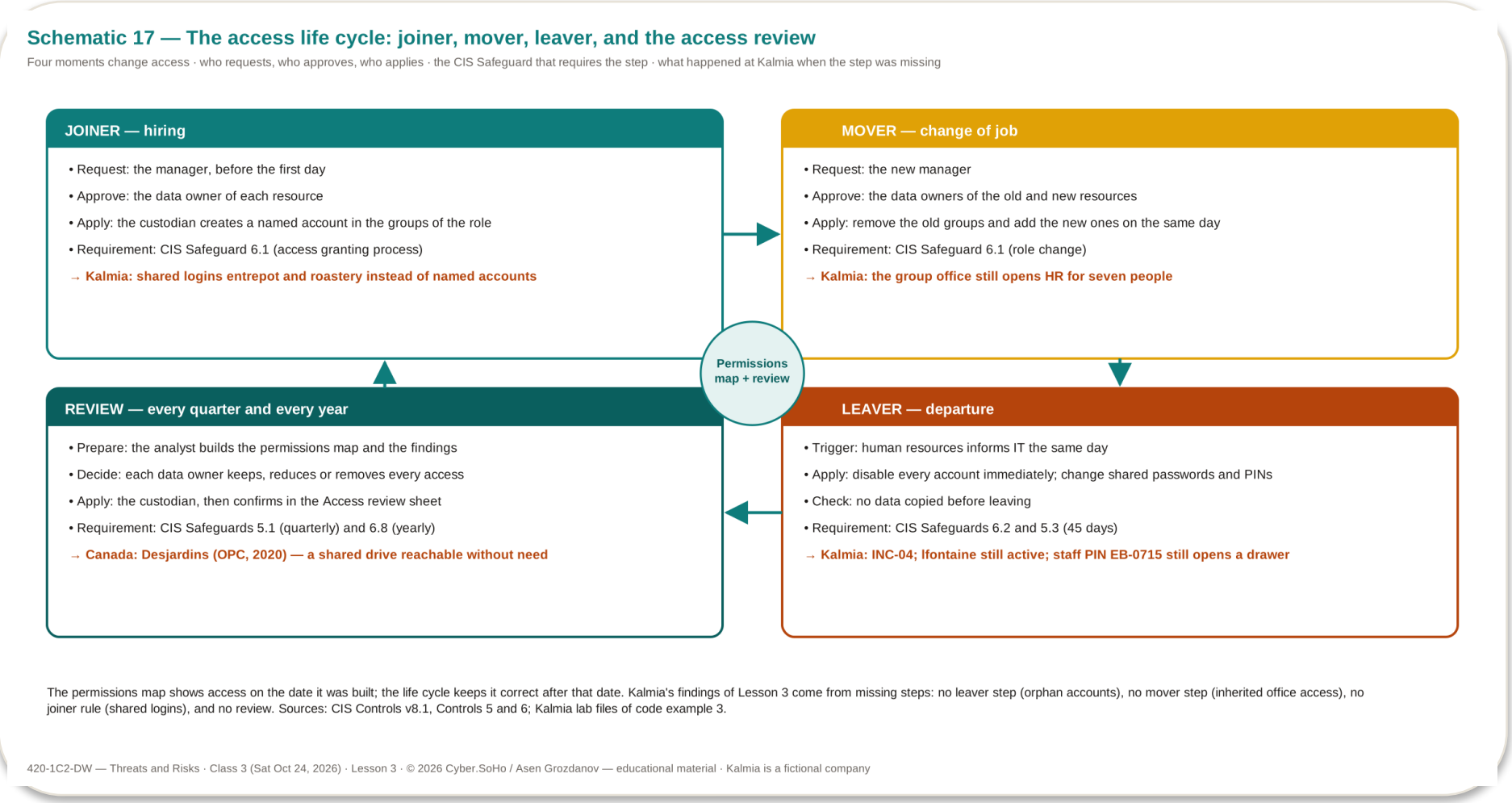
black corner = permission given directly to the person instead of a group (DIRECT-ACE)

Public share (Marketing): access above the role matrix is not a finding

Twenty findings, ten of them HIGH. Most red cells come from two entries: the group office inherits Modify on HR, and Everyone has Modify on Scans. Each finding goes to its data owner — Sophie Tremblay for Finance, HR and Scans; Karim Haddad for Production and Surveillance — who decides to keep, reduce or remove the access. Source: the output of Get-KalmiaPermissionsMap.ps1 (code example 3).

420-1C2-DW — Threats and Risks · Class 3 (Sat Oct 24, 2026) · Lesson 3 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material · Kalmia is a fictional company

Schematic 17 — The access life cycle: joiner, mover, leaver, review

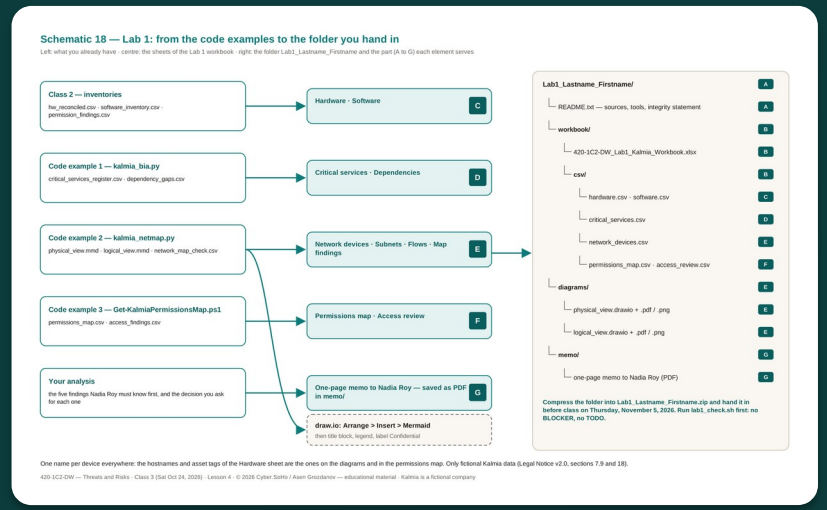


4

Lesson 4 · 0:47 – 0:57

Lab 1 — Asset inventory and infrastructure map (Integrative Project, Part 1) — start

- What Lab 1 is
- The folder you hand in
- The seven parts and their points
- From today to November 5
- Quality rules and the readiness check



Schematic 18 — Lab 1: from the code examples to the folder you hand in

What Lab 1 is

- Lab 1 — Asset inventory and infrastructure map: Integrative Project, Part 1
- Assigned today · due Thursday, November 5, 2026 (Class 5) · 5% of the final grade
- One deliverable for Nadia Roy: what Kalmia owns, cannot lose, how it is connected, who can access what
- Labs 2, 3 and 4 build on it
- The Integrative Project assembles the four labs — formative and optional

5%
of the final grade

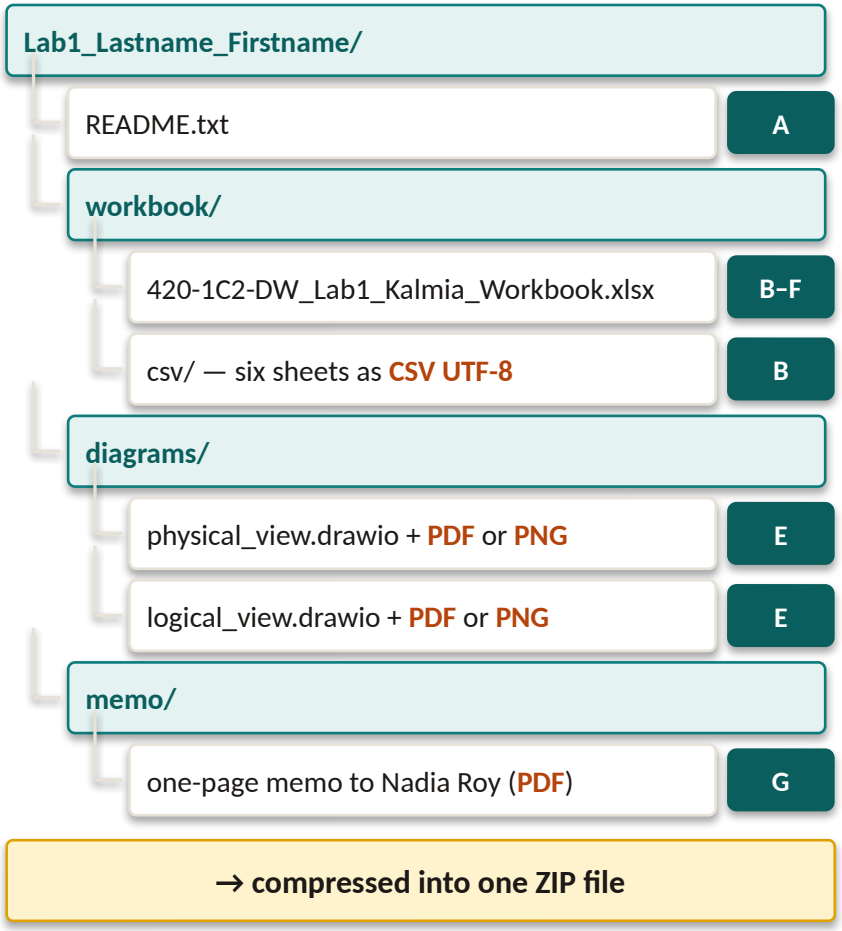
Nov 5
due date — Class 5, before class

7
parts, A to G

100
points

The folder you hand in

- One folder Lab1_Lastname_Firstname, compressed into one ZIP file
- README.txt — name, number, date, sources, tools, the integrity statement
- workbook/ — the Lab 1 workbook and, in csv/, six sheets saved as **CSV** (comma-separated values) **UTF-8** (Unicode Transformation Format, 8-bit — the standard encoding of text files)
- diagrams/ — physical_view and logical_view: .drawio and **PDF** (Portable Document Format) or **PNG** (Portable Network Graphics)
- memo/ — one page for Nadia Roy: five findings, the decision you ask for each



The seven parts and their points

Part	What it must contain	Points
A — Folder and README	folder name; README with sources, tools, integrity statement	5
B — Workbook and exports	the workbook and its six **CSV** (comma-separated values) exports, template column names	5
C — Inventories	devices with owner, approval, state; software with version, support, authorization	20
D — Critical data and services	**MTD** (maximum tolerable downtime), **WRT** (work recovery time), **RTO** (recovery time objective) shorter than the **MTD**, **RPO** (recovery point objective), tier, dependencies, gaps, single points of failure	20
E — Infrastructure map	two views, title block, legend, Confidential; same names; zones, flows; untagged resolved	25
F — Permissions and access review	effective access; every finding with owner and decision	15
G — Memo and privacy	one page for Nadia Roy; no real personal information	10
Total	100 points = 5% of the final grade	100

Late work: −10% per day, nothing accepted 7 days after the due date · literacy: up to −10% and a rewrite

From today to November 5

- Today, hours 2 and 3 — folder, workbook, outputs of code examples 1 to 3
- Week of October 26, no classes — the two views in draw.io, title blocks, legends
- By Monday, November 2 (Class 4) — the owners' decisions, the memo draft, your questions
- By Thursday, November 5, before class — run the checker, fix, compress, hand in

Sat, Oct 24 — today — hours 2 and 3

folder, workbook, outputs of code examples 1 to 3

Week of Oct 26 — no classes

the two views in draw.io

Mon, Nov 2 — Class 4

owners' decisions, memo draft, questions

Thu, Nov 5 — due — before class

checker, fixes, ZIP, hand in

Quality rules

- One name per device everywhere — Hardware sheet, diagrams, permissions map
- Dates in **ISO** (International Organization for Standardization) 8601 (2026-10-24); durations as numbers of hours
- Cite your sources: file, interview, code example
- Fictional data only — the checker blocks numbers in the format of a **SIN** (Social Insurance Number) or of a payment card
- Your own work — the course outline's academic integrity policy
- Confidential (7.5) · fictional case (7.9) · lab data only (18)

Accepted	Fix before handing in
PC-FIN-01 · KAL-0010 in every sheet and diagram	"Sophie's **PC**" in the diagram
2026-11-05 · **RTO** 6	05/11/26 · "six hours or so"
Source: bia_impacts.csv	a number with no source
fictional Kalmia data only	**a number in SIN format → BLOCKER**

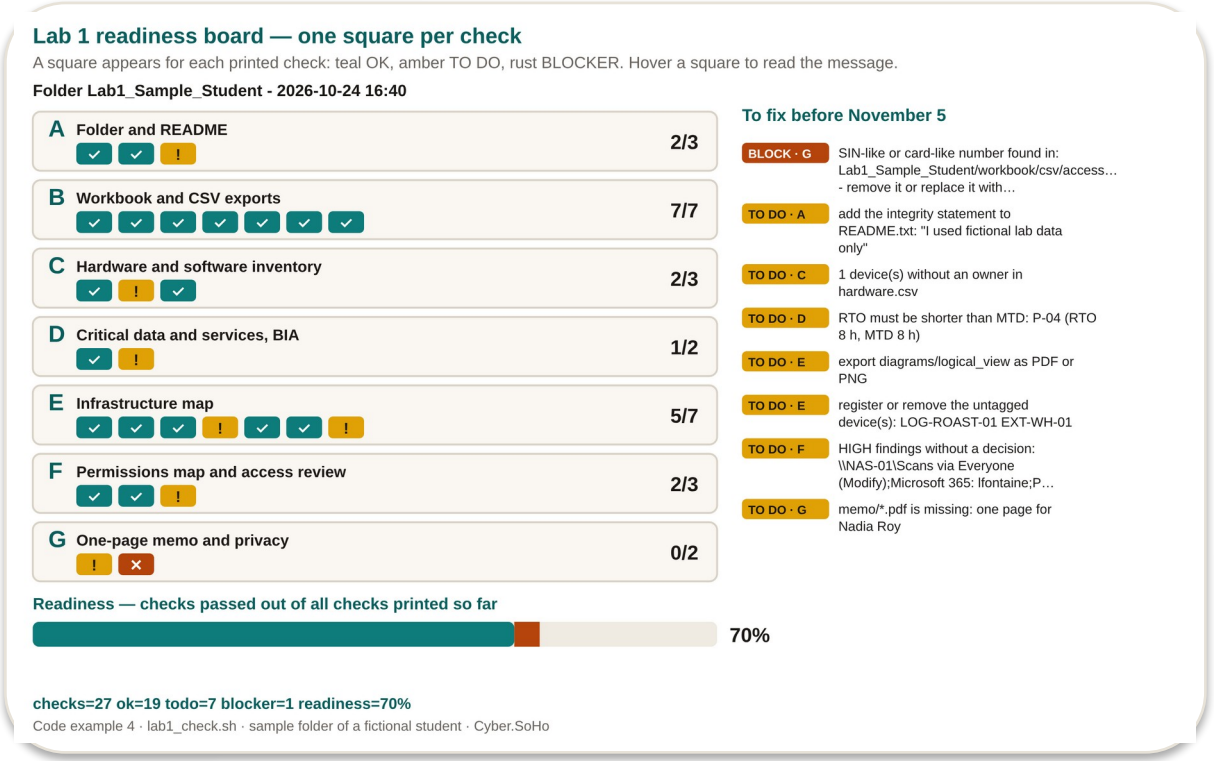
Abbreviations: **PC** (personal computer) · **RTO** (recovery time objective)

Real-life example 4 — the readiness check of a sample folder

Part	Score	What the checker found	Fix
A — README	2/3	integrity statement missing	add the sentence
B — Exports	7/7	workbook and six **CSV** (comma-separated values) files present	—
C — Inventories	2/3	KAL-0016 has no owner	ask Karim Haddad
D — Critical services	1/2	P-04: **RTO** (recovery time objective) 8 h = **MTD** (maximum tolerable downtime) 8 h	**RTO** = 8 − 2 = 6 h
E — Map	5/7	logical view not exported · two untagged devices	export · register
F — Permissions	2/3	three HIGH findings without a decision	owner's decision
G — Memo, privacy	0/2	no memo · BLOCKER: a number in **SIN** (Social Insurance Number) format	delete it first

Code example 4 — lab1_check.sh (Bash)

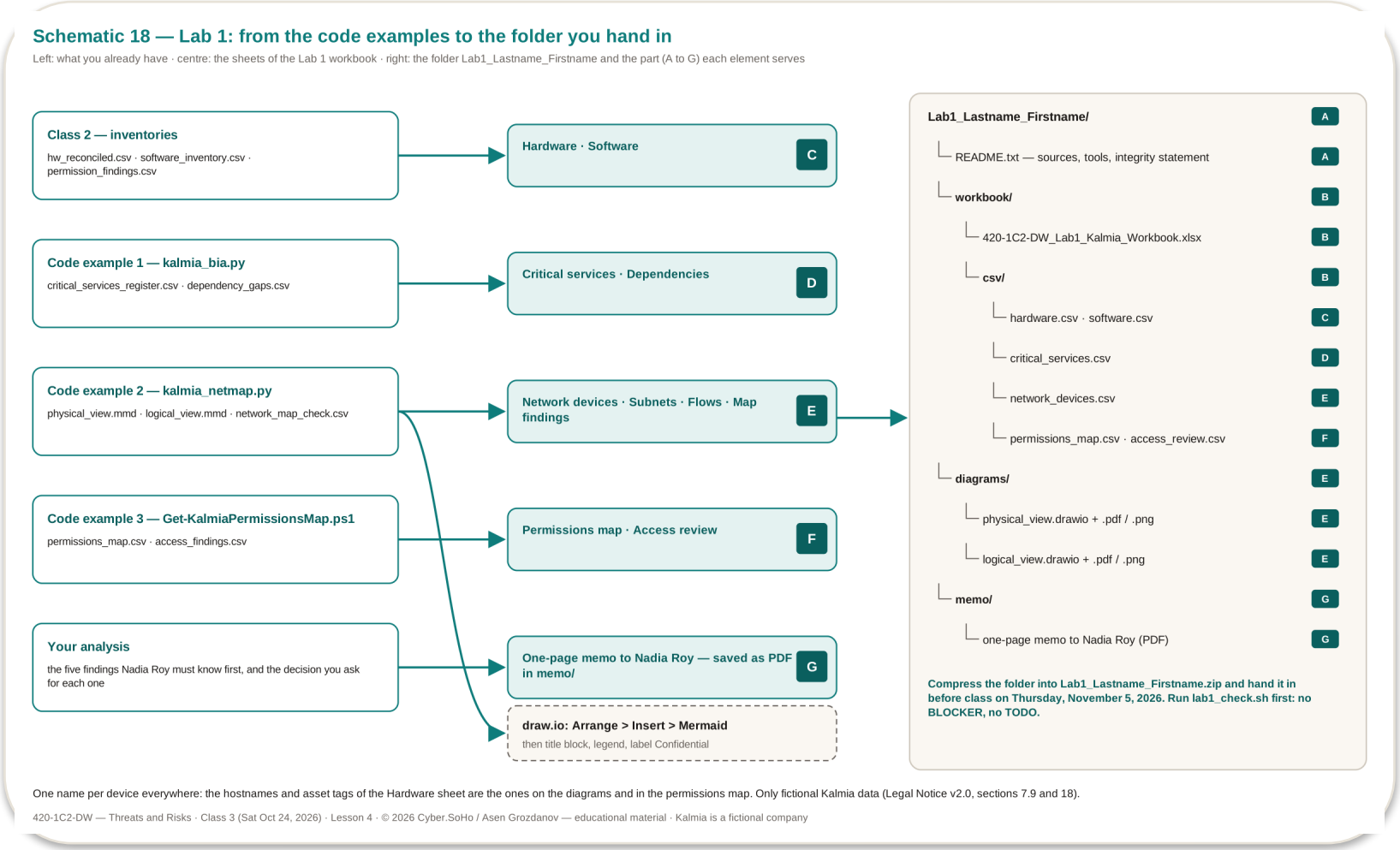
- Checks the folder name and the README
- Reads the **CSV** (comma-separated values) exports with a small awk program
- Required columns, owners, **RTO** (recovery time objective) < **MTD** (maximum tolerable downtime), asset tags
- Diagrams and their exports; HIGH findings decided
- BLOCKER: a number in the format of a **SIN** (Social Insurance Number) or of a card
- Prints the readiness and writes lab1_readiness.txt



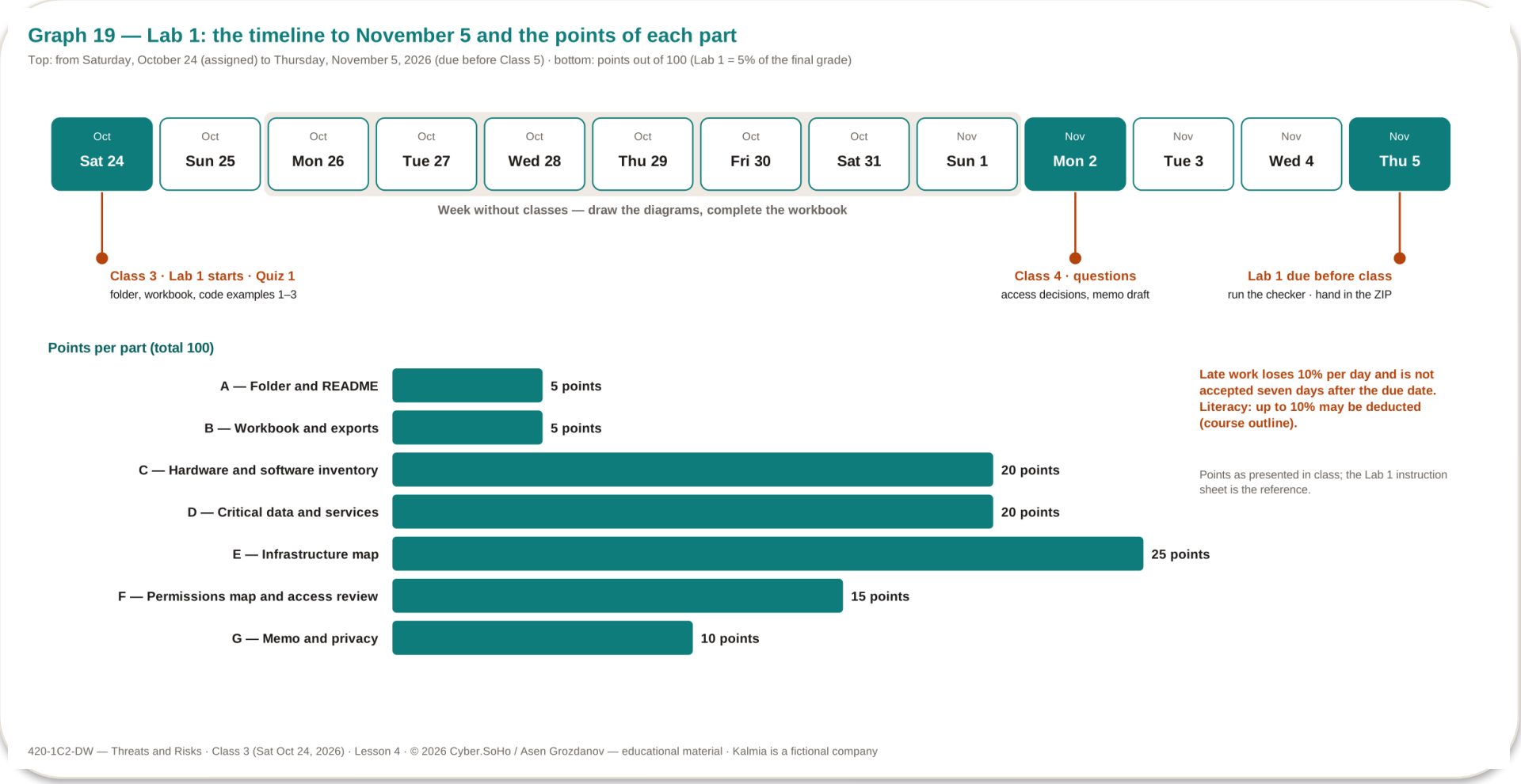
Final state of the code runner's visualization in the lecture module

```
$ ./lab1_check.sh Lab1_Sample_Student
```

Schematic 18 — From the code examples to the folder you hand in



Graph 19 — Lab 1: the timeline and the points of each part



Quiz 1 — Topics 1 and 2

- Covers Topic 1 (Class 1) and Topic 2, Parts 1 and 2 (Classes 2 and 3)
- 25 questions: 15 **MCQ** (multiple-choice question) with one answer · 10 **MSQ** (multiple-select question), each stating how many answers are expected
- Today, online on **TIC-FP** (the Chamilo-based online learning platform of the course) — at the time announced in class (suggested: 4:40 – 5:15 pm)
- 5% of the final grade (course outline)
- Individual; the questions are confidential (Legal Notice 17.2)
- Missed with a valid reason: a make-up; more than 5 days → medical certificate

25

questions: 15 **MCQ** + 10 **MSQ**

5%

of the final grade

TIC-FP

online, today

17.2

the questions are confidential

Videos for today (1/2) — Lessons 1 and 2

Lesson 1 — **States of Data — CompTIA Security+ SY0-701 — 3.3**

Data at rest, data in transit and data in use, and why the country where data is stored matters: the three places a data inventory must look for each type of critical data.

Professor Messer · 6 min 07 s — ▶️ Watch on YouTube

Lesson 1 — **Business Impact Analysis — CompTIA Security+ SY0-701 — 5.2**

Recovery time objective, recovery point objective, mean time to repair and mean time between failures: the numbers a business impact analysis produces for each critical process.

Professor Messer · 2 min 55 s — ▶️ Watch on YouTube

Lesson 2 — **Network Documentation — CompTIA Network+ N10-009 — 3.1**

Physical and logical network diagrams, rack diagrams, cable maps, IP address management and asset inventories: the documents a network map is built from, and how they are kept up to date.

Professor Messer · 10 min 42 s — ▶️ Watch on YouTube

Lesson 2 — **Segmentation and Access Control — CompTIA Security+ SY0-701 — 2.5**

Why a network is divided into segments, and how access control lists and application allow lists control what may cross from one segment to another — the reasoning behind the zones of a logical diagram.

Professor Messer · 6 min 06 s — ▶️ Watch on YouTube

Abbreviations: IP (Internet Protocol)

Videos for today (2/2) — Lessons 3 and 4

Lesson 3 — **Access Controls — CompTIA Security+ SY0-701 — 4.6**

Least privilege and the access control models — mandatory, discretionary, role-based, rule-based, attribute-based — that a permissions map is checked against.

Professor Messer · 7 min 49 s

▶️ Watch on YouTube

Lesson 3 — **Identity and Access Management — CompTIA Security+ SY0-701 — 4.6**

Provisioning and de-provisioning of accounts, permission assignments, single sign-on and federation: the life cycle of every account that appears on a permissions map.

Professor Messer · 12 min 46 s

▶️ Watch on YouTube

Lesson 4 — **How to Create a Basic Network Diagram Using Draw.io**

A step-by-step demonstration in draw.io: choosing network shapes, placing the devices, connecting and labelling them — the tool you use for the two diagrams of Lab 1.

My Coding Project · 11 min 38 s

▶️ Watch on YouTube

Thank you — questions?

After the break: the Lab 1 work session, then Quiz 1 on **TIC-FP** at the announced time
Next: Class 4 — Monday, November 2, 2026, 6–10 pm, online
Topic 3 (Part 1) — threat actors, internal threats, attack methods

Lab 1 (5%) — due Thursday, November 5, 2026, before class

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !
ALL Rights Reserverd